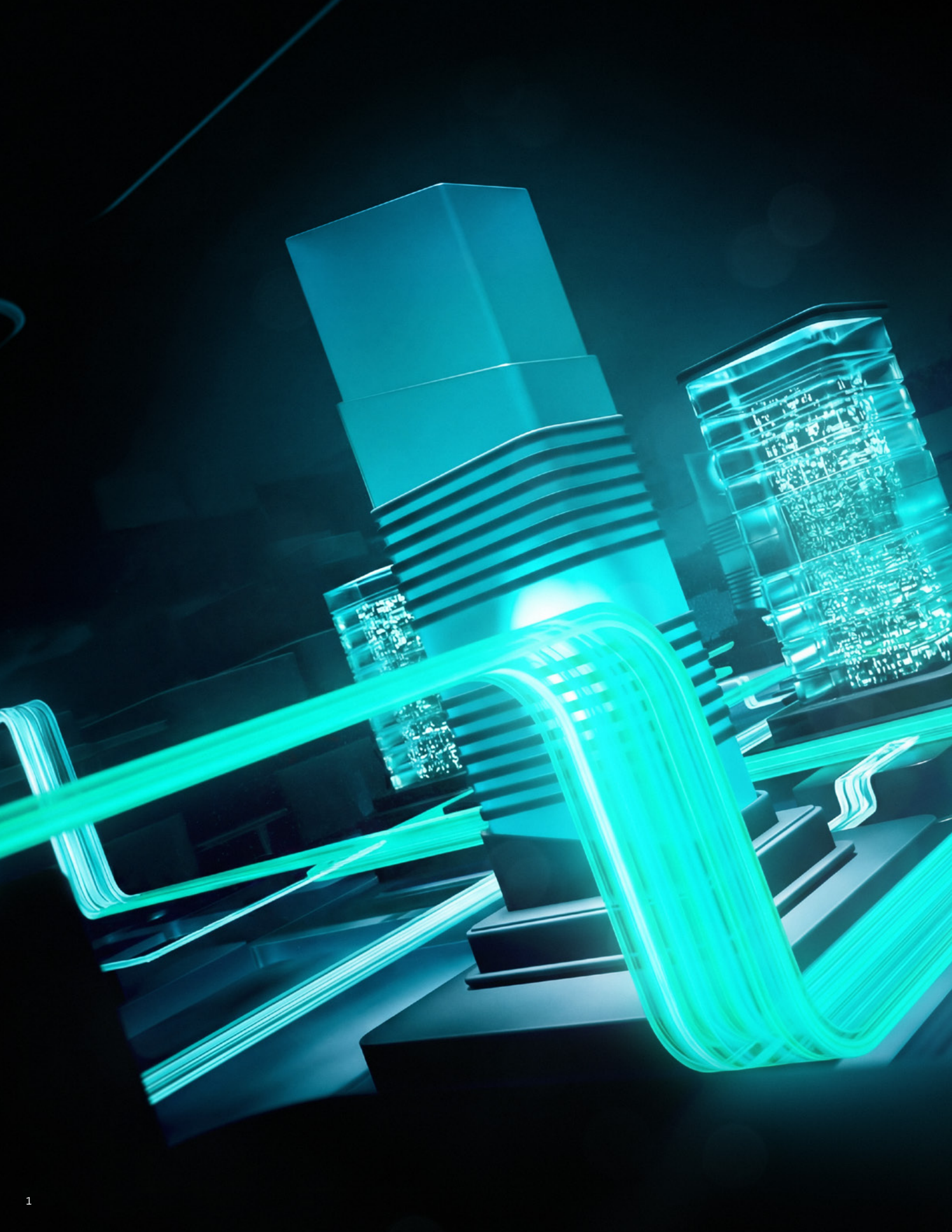


2026



AI THREAT LANDSCAPE REPORT

THE RISE OF AGENTIC AI



I TABLE OF CONTENTS

04 FOREWORD

05 SECURITY FOR AI SURVEY INSIGHTS AT A GLANCE

11 AI THREAT LANDSCAPE TIMELINE

13 WHAT'S NEW IN AI

17 PART 1: RISKS POSED BY ARTIFICIAL INTELLIGENCE

17 Risks to Society

20 AI-Powered Cybercrime

26 PART 2: RISKS FACED BY AI-BASED SYSTEMS

26 Attacks on Model Foundations

30 Attacks Against GenAI

33 Agentic Systems Security

39 AI Supply Chain Security

47 PART 3: ADVANCEMENTS IN SECURITY FOR AI

47 Defensive Frameworks and Initiatives

51 The State of AI Red Teaming

51 New Guidance & Legislation

57 Part 4: Predictions and Recommendations

57 Predictions for 2026

60 Recommendations for the Security Practitioner

61 About HiddenLayer & Resources



I FOREWORD

We are entering the next phase of the AI revolution. What began as predictive models and generative interfaces is rapidly evolving into autonomous, agentic systems capable of planning, reasoning, and acting on our behalf. In 2026, no mission, enterprise, or government agency will remain untouched by AI agents operating across workflows, networks, and critical infrastructure.

Agentic AI represents a profound leap forward. These systems are no longer limited to responding to prompts. They can set goals, call tools, interact with other systems, generate code, initiate transactions, and adapt dynamically to changing environments. Properly harnessed, they promise unprecedented operational efficiency, accelerated innovation, and entirely new models of productivity. But autonomy changes the risk equation.

When AI systems are empowered to take action, the attack surface expands dramatically. The same capabilities that enable agents to automate business processes can be manipulated to automate exploitation. The same reasoning loops that drive efficiency can be redirected toward malicious objectives. As AI gains agency, adversaries gain leverage.

Make no mistake, the defining AI security challenge of this era is not hypothetical superintelligence. It is the weaponization, manipulation, and compromise of autonomous systems by bad actors.

Agentic architectures introduce new layers of vulnerability, including tool poisoning, memory manipulation, model context hijacking, multi-agent collusion, identity abuse, data exfiltration via action chains, and the exploitation of decision-making loops. These risks are not theoretical. They are emerging now across commercial enterprises and federal environments, experimenting with AI-driven automation.

Traditional cybersecurity principles remain essential, but they are no longer sufficient on their own. Securing agentic AI demands continuous validation of model behavior, real-time inspection of agent actions, guardrails around tool access, and controls that account for systems capable of independent execution. The convergence of AI security and application security has never been more urgent.

In this year's report, we examine how the rise of agentic AI is reshaping the threat landscape. We detail the novel attack patterns targeting autonomous systems and analyze how adversaries are adapting proven tactics to exploit AI-driven workflows. We share findings from security and AI leaders deploying agents in production environments, along with data-driven insights from our work securing enterprise AI systems. Finally, we highlight advancements in protective controls purpose-built for agentic architectures.

As organizations race toward autonomy, security must move just as quickly. Innovation without protection invites disruption. Autonomy without oversight invites abuse.

Let this report serve as a guide for navigating the agentic era responsibly. Whether you are building, deploying, or defending autonomous systems, we invite you to join us in securing AI not just as a tool, but as an actor in our digital world.

We are proud to present the 2026 HiddenLayer AI Threat Landscape Report.

Tito

CEO & Co-Founder
(Unassisted by LLMs)

SECURITY FOR AI SURVEY INSIGHTS AT A GLANCE

This year's survey reveals a growing disconnect between how AI systems are being deployed and how they are being secured. Organizations are rapidly operationalizing AI with increasing autonomy, while security programs remain largely optimized for static models and traditional application controls. Foundational safeguards such as encryption and secure deployment are now common, but the operational controls required to manage agentic behavior, provide runtime visibility, conduct adversarial testing, and implement AI-specific incident response remain unevenly implemented. As AI systems gain the ability to act, integrate, and make decisions independently, these gaps are no longer theoretical; they are becoming sources of systemic enterprise risk.

That risk is amplified by limited detection confidence and fragmented accountability. Nearly one-third of organizations cannot definitively determine whether they experienced an AI security breach in the past year, even as attacks remain steady or increase and frequently originate from public models, chatbots, and agent-enabled systems. Shadow AI further

erodes control, with most organizations acknowledging untracked deployments that bypass governance, monitoring, and approval processes. In agentic environments, delayed detection and unclear ownership are not just inefficiencies; they enable autonomous systems to propagate harm faster than traditional security models were designed to handle.

At the same time, AI has become foundational to business operations. Most organizations now consider both internally operated and third-party AI systems critical to revenue, customer experience, and operational resilience, yet confidence in vendor security remains limited. Taken together, the findings reinforce a core conclusion reflected throughout this report: AI systems should be assumed exploitable, not merely vulnerable. Securing AI in an agentic era requires a shift away from one-time controls and policy assertions toward continuous accountability, runtime monitoring, enforceable governance, third-party assurance, and security mechanisms designed for systems that evolve and act beyond human-in-the-loop oversight.

AI's Critical Role in Business Success

88%

of organizations report that **most or all internally operated AI models are critical to business success.**

97%

state that **AI projects are critical or important to revenue generation** over the next 18 months.

78%

report that **embedded third-party AI models are also business-critical**, extending risk beyond internal deployments.

92%

say AI is critical or important to **customer experience**, and **96% to core business operations**, raising the impact of AI security failures.

Rising Attacks — With Uneven Detection Confidence

69%

of organizations **definitely know** whether they experienced an AI security breach in the past 12 months.

31%

report uncertainty, indicating persistent gaps in monitoring and detection as AI systems gain autonomy.

71%

say **attacks on AI systems have increased or remained the same** compared to the previous year.

Attack Vectors for AI Breaches

35%

Malware in models pulled from public repositories

31%

Attack on internal or external chatbot

14%

Third-party applications

13%

Attacks on agents

6%

Inference attacks on predictive models

Sources & Motivations of AI Attacks

Top Sources of AI Attacks

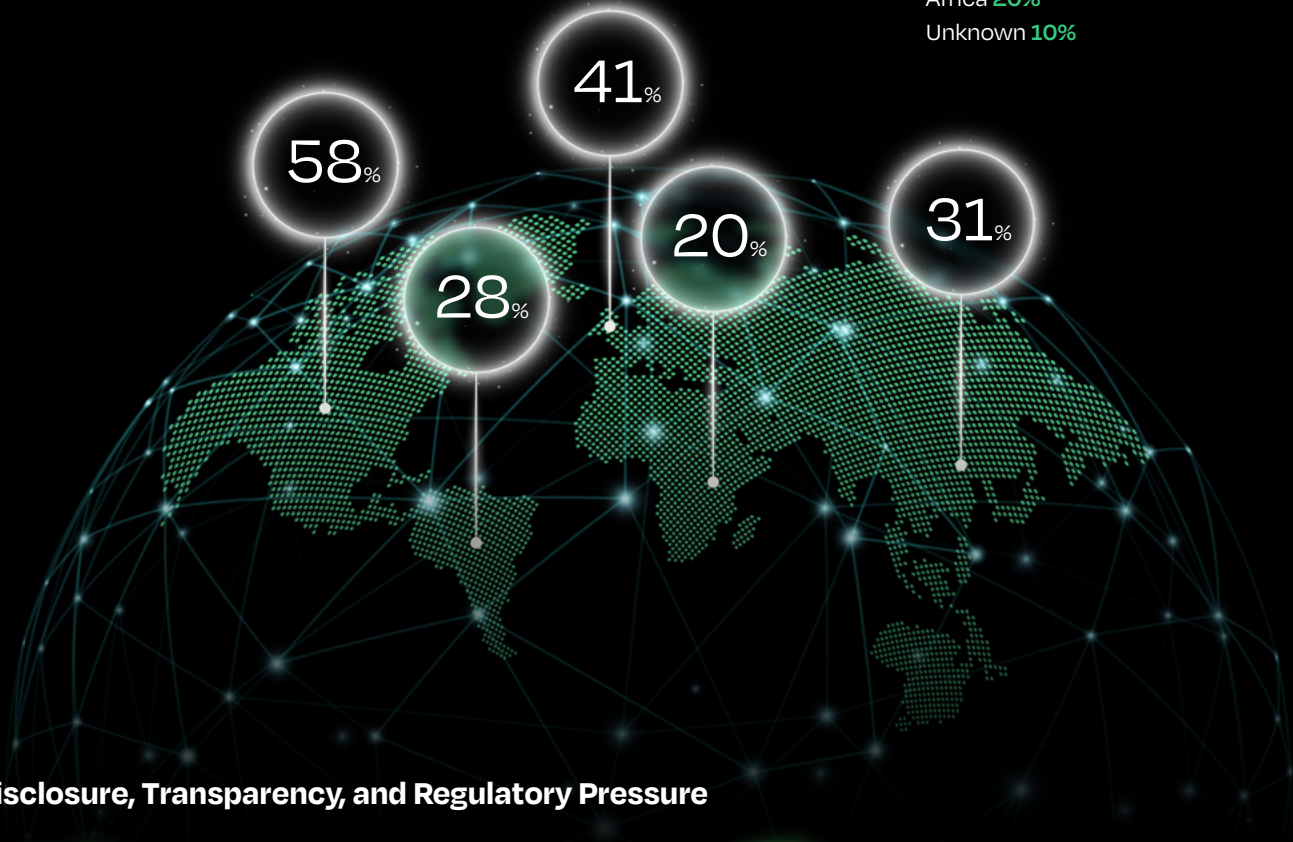
- Criminal hacking groups — 52%
- Third-party service providers — 45%
- Freelance hackers — 38%
- Competitors — 35%
- State-sponsored actors — 31%

Top Motivations for AI Attacks

- Financial gain — 50%
- Sensitive data exfiltration — 48%
- Business disruption — 42%
- Model theft — 39%
- Competitive advantage — 27%

GLOBAL ORIGINS OF AI ATTACKS

North America **58%**
Europe **41%**
Asia **31%**
South America **28%**
Africa **20%**
Unknown **10%**



Disclosure, Transparency, and Regulatory Pressure

85%

of leaders agree that companies should be legally required to disclose AI security breaches.

53%

However, 53% report that their organization has opted not to disclose an AI incident due to reputational concerns.

Challenges in Securing Agentic AI

- 76% report that shadow AI—unapproved or untracked AI deployments—is a definite or probable problem, but only 34% partner externally for detection.
- 93% use open-weight models from repositories such as AWS, Azure, and Hugging Face, increasing exposure to supply chain risk, yet fewer than half report consistently scanning inbound models for malicious content or integrity issues.

Top Third-Party GenAI Applications in Use

- ChatGPT — 77%
- Microsoft Copilot — 68%
- Gemini — 57%
- Claude — 32%
- Salesforce — 27%

Time and Resources Devoted to AI Security

- On average, professionals report spending 46% of their time addressing AI risk and security.
- 91% have added budget for AI security in 2025.
- However, only 58% allocate 10% or more of AI spending to risk and security mitigation, suggesting underinvestment relative to dependency.

SECURITY MEASURES & GAPS IN AGENTIC AI DEFENSE

Most Common AI Security Practices



Governance, Frameworks, and Accountability



Top Frameworks Used to Guide AI Security

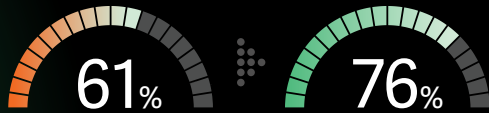
- Gartner AI Trust, Risk, and Security Management — 57%
- Google Secure AI Framework — 56%
- IBM Framework for Securing Generative AI — 53%
- NIST AI Risk Management Framework — 48%
- Databricks AI Security Framework — 41%

YEAR-OVER-YEAR

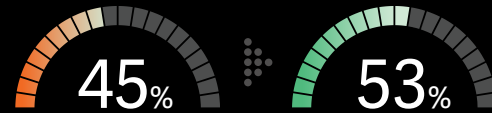
2025 2026

Exposure & Disclosure

Organizations identifying shadow AI as a known or probable risk

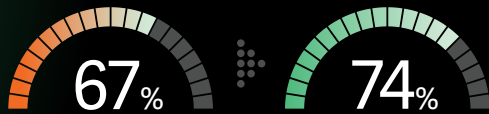


Organizations admitting they withheld disclosure due to backlash concerns

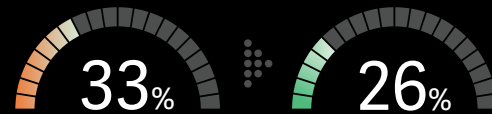


Visibility & Detection

Organizations definitively know that they have experienced an AI-specific breach

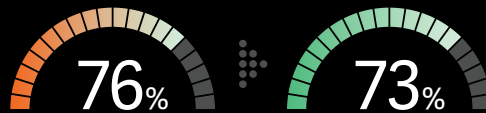


Organizations reporting they probably don't know, don't know, or have no way to know if an AI breach occurred



Organizational Dynamics

Organizations reporting internal debate or conflict over AI security initiatives



AI Criticality

AI projects rated critical or important to revenue generation



Organizations saying all or most operated AI models are critical to business success



Survey Highlights

- 1 in 8 AI breaches are a result of AI agents
- Over 1/3rd of AI breaches are a result of AI chatbots
- Governance Exists - But It's Chaotic
 - 83% have governance committees, 73% report conflict, and only 68% have role clarity
- Open-weight models are the top source of AI breaches
 - Malware in public repositories accounts for 35% of breaches, yet 93% of organizations still use them

| AI THREAT LANDSCAPE IN A NUTSHELL



Risks related to the use of AI



Evolution of risks faced by AI-based Systems



Poisoning attacks



Inference attacks (Model evasion & theft)



AI supply chain attacks (Model hijacking: serialization vulnerabilities & graph backdoors)



GenAI prompt attacks (Guardrail bypass, indirect prompt injection, prompt obfuscation)



Attacks against agentic systems



AI THREAT LANDSCAPE TIMELINE 2025

AI Milestones, Risks Posed by AI, Risks Faced by AI, Security Initiatives

JAN

- OpenAI launches Operator - one of the first AI agents
- ServiceNow launches AI Agents & Orchestrator
- Google agrees to invest \$1 billion into Anthropic
- A study published in Nature Medicine reveals medical LLMs highly prone to poisoning
- Model genealogy technique called ShadowGenes published by HiddenLayer

FEB

- Anthropic launches Claude 3.7 Thinking
- OpenAI launches GPT-4.5 and Deep Research
- Storm-1516 disinformation operation targets elections in Germany
- Basilisk Venom attack shows how hidden prompts can create backdoors in models
- OWASP starts their Agentic Security Initiative
- Cloud Security Alliance releases Agentic AI Threat Modeling Framework MAESTRO

MAR

- OpenAI adopts MCP across its products
- Microsoft integrates agents into Copilot Studio
- Google releases Gemini 2.5 Pro - thinking model with advanced reasoning

APR

- Microsoft introduces Agent Flows - An AI workflow automation in Copilot Studio
- Google launches MCP Toolbox for Databases
- Google introduces Agent2Agent protocol for inter-agent communication
- Teenager dies after confiding suicidal thoughts to ChatGPT
- Paper "Machine Unlearning Fails to Remove Data Poisoning" published at ICLR 2025
- Researchers prove simple interference can fool traffic sign recognition in self-driving cars

- A novel universal bypass for all major LLMs unveiled by HiddenLayer
- Invariant Labs discovers MCP vulnerability that allows for tool poisoning attacks
- SpiderLabs publishes Agent In the Middle - a technique of abusing A2A protocol
- Model Signing Project v 1.0 released by OpenSSF AI/ML Working Group

MAY

- Anthropic launches Claude 4 and makes Claude Code generally available
- MS announces native support for MCP on Windows 11
- Docker creates MCP catalogue
- HiddenLayer's researchers demonstrate parameter abuse in MCP servers
- MITRE proposes a defender-focused framework SAFE-AI
- The first AI SBOM generator tool unveiled at RSA 2025 conference

JUN

- Salesforce releases Agentforce 3.0
- Researchers at CyLab demonstrate data poisoning attacks with 0.1% of poisoned dataset
- CVPR 2025 papers take backdoor and evasion attacks on models to the next level
- HiddenLayer demonstrates TokenBreak - a method to bypass guardrail models
- Asana discloses a major cross-tenant breach caused by a bug in their MCP server
- Backslash Security's research finds hundreds of misconfigured MCP servers
- HiddenLayer publishes the APE taxonomy for classification of prompt attacks

JUL

- ◉ AWS introduces Kiro AI - an agentic IDE
- ◉ Cognition acquires Windsurf AI IDE
- ◉ Microsoft creates Dataverse MCP Server
- ◉ Microsoft introduces Edge Copilot - an AI mode for the Edge browser.
- ◉ Perplexity AI introduces Comet - a browser with an integrated AI assistant
- ◉ Man dies by suicide after receiving encouraging messages from ChatGPT
- ◉ Vinciworks reports over 50 cases involving fake legal citations generated by AI
- ◉ CERT-UA discovers LAMEHUG, an infostealer that relies on LLM
- ◉ HiddenLayer demonstrates hidden prompt injections that can hijack AI code assistants
- ◉ Critical RCE Vulnerability found in mcp-remote package
- ◉ Coalition for Secure AI publishes Principles for Secure-by-Design Agentic Systems

AUG

- ◉ OpenAI releases GPT-5
- ◉ Man hospitalized after trusting ChatGPT advice
- ◉ Man murders his mother and kills himself after ChatGPT fuels his paranoid delusions
- ◉ Anthropic releases report detailing the first fully automated cybercrime campaign
- ◉ Anthropic's Report highlights the use of AI in romance scams and remote worker fraud
- ◉ The first known AI-powered ransomware, PromptLock, is discovered by ESET
- ◉ HiddenLayer unveils VISOR - a technique of modifying model behavior using images
- ◉ HiddenLayer demonstrates persistent logical backdoors
- ◉ Major supply chain breach through Salesloft's Drift AI chatbot impacts hundreds of businesses
- ◉ S1ngularity becomes the first known supply chain attack that scans for and leverages locally accessible LLMs

SEP

- ◉ Anthropic launches Claude 4.5 Sonnet & Opus
- ◉ Opera launches Neon agentic browser
- ◉ Google introduces Agent Payment Protocol
- ◉ Nvidia intends to invest \$100 billion into OpenAI
- ◉ ASML & Mistral AI enter strategic partnership
- ◉ Disinformation campaign spreads deepfakes targeting

Moldova's election

- ◉ HiddenLayer unveils practical code assistant AI viruses
- ◉ Koi discovers the first malicious MCP server in the wild

OCT

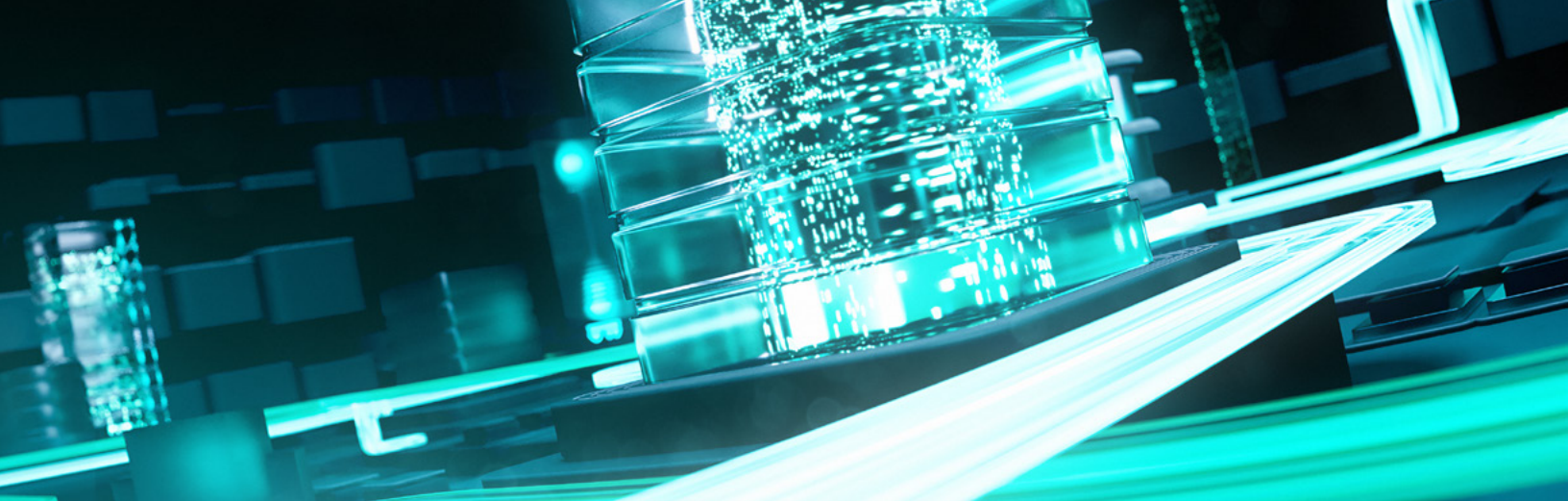
- ◉ OpenAI launches ChatGPT Atlas agentic browser
- ◉ Amazon Bedrock AgentCore becomes generally available
- ◉ Researchers prove that even as little as 250 malicious documents can poison LLMs
- ◉ The Virus Infection Attack (VIA) is introduced at NeurIPS 2025
- ◉ Deserialization vulnerability in Keras (CVE-2025-49655) is disclosed by HiddenLayer
- ◉ CoSAI publishes AI Incident Response Framework v1.0

NOV

- ◉ Anthropic releases Claude Opus 4.5
- ◉ Google launches Antigravity - an agent-first IDE
- ◉ Release of Clawdbot (now OpenClaw) - a free, open-source personal AI assistant
- ◉ Anthropic unveils the first AI-driven, large-scale cyber espionage campaign
- ◉ Google details several strains of novel AI-powered malware
- ◉ UK consumers warned over AI chatbots giving inaccurate financial advice
- ◉ HiddenLayer publishes EchoGram - a vulnerability undermining AI guardrails

DEC, 2025 - EARLY JAN, 2026

- ◉ Google Gemini 3 Deep Think
- ◉ Mistral AI launched the Mistral 3 family
- ◉ OpenAI releases GPT-5.2
- ◉ Google adds MCP support for Google services
- ◉ WIRED enquiry uncovers one of the first instances of deepfake-as-a-service
- ◉ Sexualized deepfake content generated with Grok floods xAI
- ◉ The Chameleon's Trap campaign uses phishing emails with hidden prompt injections
- ◉ HiddenLayer researchers port ShadowLogic backdoor into agentic settings
- ◉ Checkmarx reveal model confusion attacks on Hugging Face
- ◉ OWASP formally launches their AIBOM Project
- ◉ OWASP releases Top 10 for Agentic Applications
- ◉ NIST releases preliminary draft of their Cyber AI Profile



WHAT'S NEW IN AI

A year has passed since our [previous AI Threat Report](#), and the landscape of generative AI has shifted significantly, with the pace of improvements through 2025 matching, and in some cases exceeding, that of the previous year. Among these developments, the most significant include the evolution of deep reasoning models, alongside smaller, highly specialized Edge AI models, and the rapid popularization of agentic AI systems.

2025 Inflection Points

Generative AI models have continued to grow in scale, capability, and versatility, and over the past 12 months, have introduced new capabilities such as reasoning and self-improvement. These capabilities have become central to how modern foundation models operate.



Early Reasoning Models

DeepSeek R1 & OpenAI O1

Emergent Reasoning
Structured Inference



Next Generation Models

GPT-5.2, Gemini 3, Opus 4.6

Extended Reasoning
Multi-Domain Problem-Solving

What began with early reasoning models such as DeepSeek and OpenAI's O1 has since led to more advanced foundation models like OpenAI's [GPT-5.2](#), Google's [Gemini Deep Think](#), and Claude [Opus 4.6](#) that explicitly allocate inference time to reason through complex problems before producing an answer. This capacity for pausing and reflection affects how LLMs handle [mathematical proofs](#), scientific questions, and situations where nuance matters.

In addition to building larger general-purpose models, there is also a trend of improving small, specialized models designed for deployment in smartphones, autonomous vehicles, IoT sensors, and other embedded systems. These so-called [tiny models](#), compact enough to run entirely on-device, have become increasingly desirable as organizations shift from centralized cloud infrastructure toward local, or edge-based, deployment.

While [edge AI](#) may lack the breadth and flexibility of cloud-based systems, it benefits from deep specialization tailored to the specific domains in which it is deployed, including healthcare, finance, defense, and transportation. They also offer benefits that are critical in many environments, particularly in critical infrastructure, including improved privacy, low-latency responses, and offline operation.

The conversation around autonomous AI agents gained momentum in 2024, but it wasn't until 2025 that things truly began to take shape. The shift from experimental demonstrations to production-grade systems occurred rapidly, as major vendors expanded AI capabilities beyond question answering into autonomous task execution.

AI agents vary widely in form and function, with applications spanning a broad range of use cases. For the purpose of

simplicity, two primary categories of AI agents emerged in 2025: general-purpose agents, which are multifunctional, desktop-integrated assistants, and application-specific agents, designed to operate within narrowly defined software environments.

Below are a few high-profile pioneering examples, as several businesses across sectors followed with the release of their own solutions.

Type	Developer	Name	Description	Initial Release Date
Multipurpose user assistant	Google	Project Mariner	An experimental Chrome extension capable of browsing websites and reasoning across browser content.	Prototype introduced in late 2024
Multipurpose user assistant	OpenAI	Operator	One of the first AI agents built to navigate websites and complete tasks on behalf of users. Now fully integrated into the ChatGPT agent.	January 2025
Multipurpose user assistant	OpenAI	Deep Research	Model focused on information retrieval and data analysis, capable of performing multi-step research for more complex tasks. Now unified into a ChatGPT agent.	February 2025
Multipurpose user assistant	Google	Gemini 2.5	Introduced agentic and reasoning capabilities.	March 2025
Multipurpose user assistant	Anthropic	Claude 4 Sonnet & Opus	Models with agentic capabilities and extended thinking.	March 2025
Multipurpose user assistant	Anthropic	Claude 4.5 Sonnet	Further evolution of reasoning and agentic features.	September 2025
Multipurpose user assistant	Anthropic	Claude 4.5 Opus	Further evolution of reasoning and agentic features.	November 2025
Multipurpose user assistant	Google	Gemini 3 & Gemini 3 Deep Think	Improved agentic and reasoning capabilities.	December 2025
Agentic browser	Microsoft	Edge Copilot	AI mode for Edge browser.	July 2025
Agentic browser	Perplexity AI	Comet	A browser with an integrated AI assistant and Perplexity's AI search engine.	March 2025
Agentic browser	OpenAI	ChatGPT Atlas	A browser with a built-in ChatGPT agent.	October 2025
Agentic browser	Opera	Neon	A browser with agentic capabilities.	December 2025
Coding assistant	Cognition	Windsurf	Agentic IDE.	November 2024; acquired by Cognition in July 2025
Coding assistant	Anthropic	Claude Code	Terminal-first AI coding assistant that deeply understands full codebases using agentic search to scan and interpret entire projects without manual file selection.	February 2025

Type	Developer	Name	Description	Initial Release Date
Coding assistant	Open AI	Codex agent	Cloud-based software engineering agent.	May 2025
Coding assistant	AWS	Kiro	Agentic IDE.	July 2025 (preview), November 2025 (GA)
Coding assistant	Google	Antigravity	Enables developers to delegate complex coding tasks to autonomous AI agents.	November 2025
AI automation framework	n8n GmbH	n8n	An AI workflow automation framework that evolved into an agentic solution.	Late 2024 - early 2025
AI agent platform	ServiceNow	AI Agent Orchestrator	A central management system for AI agents specialized in IT service management, HR, CRM, and risk management.	January 2025
AI automation framework	Microsoft	Agent Flows	An AI workflow automation feature built into Microsoft Copilot Studio.	April 2025
AI agent platform	Salesforce	Agentforce 3.0	A suite of native AI agents designed to support a wide range of business operations.	June 2025
AI agent platform	Amazon	Bedrock AgentCore	A platform for building, deploying, and scaling AI agents.	July 2025 (preview); October 2025 (GA)

Protocols Standardization

The speed at which agentic applications evolved is very notable. Behind the scenes, though, infrastructure has emerged as the defining factor. For agents to work across different systems and services, everyone needs to speak the same language, and 2025 saw an explosion of protocols and tooling that made this possible. The [Model Context Protocol](#) (MCP), introduced by Anthropic in late 2024, gained significant traction as a standardized mechanism for connecting AI agents to external data sources and tools. Google's [Agent-to-Agent](#) (A2A) protocol emerged in April 2025 as the first standard for inter-agent communication. A few months later, Google released the [Agent Payment Protocol](#) (AP2), aimed at enabling secure, agent-initiated payments. Numerous companies rushed to release their own agentic frameworks during this period, including OpenAI's Agent Kit, Strands Agents SDK, and Amazon's Bedrock AgentCore. It's become clear that agentic AI depends not only on model capability but on a broader ecosystem of supporting infrastructure.

Major technology providers have moved quickly to support these protocols, reflecting their strategic importance for future AI platforms. Google released the [MCP Toolbox for databases](#) and announced [MCP support for Google Services](#). OpenAI added [remote MCP support](#) and wrapped some of their existing tools to work within the protocol. Microsoft built [MCP support directly into Windows](#) and created a [Dataverse MCP server](#). Chrome got [DevTools MCP integration](#). This was followed by rapid adoption across the ecosystem, with AWS, GitHub, Salesforce, Asana, Cloudflare, PayPal, Stripe, and dozens of others deploying their own MCP servers. Docker even created an entire [MCP catalog](#) to help developers find and deploy them.

Within months, what started as a niche technical specification became the standard way that AI agents connected to the rest of the digital world. Today, MCP boasts [100 million downloads each month](#). Unfortunately, as everybody rushes to deploy agentic solutions, the security of these systems lags behind, creating a vast new attack vector.

Major Investments & Partnerships

Investment in AI during 2025 reached levels that would have seemed implausible only a few years earlier, with deals that reshaped the competitive landscape almost overnight.

At the beginning of 2025, tech giants pledged \$500 billion to the [US Stargate Project](#), and [Google agreed to invest \\$1 billion into Anthropic](#), continuing its strategy of backing multiple horses in the race while hedging against being left behind. In September, [Nvidia's commitment to invest a whopping \\$100 billion into OpenAI](#) made headlines for weeks, not just because of the size, but because it cemented the relationship between the world's dominant chip maker and one of the leading AI labs. Elon Musk's [xAI managed to raise \\$10 billion](#) at a staggering \$200 billion valuation, indicating that despite an increasingly crowded market, investors continue to back new entrants with sufficient capital and strategic positioning. On the other side of the pond, French-based [Mistral AI entered a strategic partnership with ASML](#), the Dutch semiconductor equipment

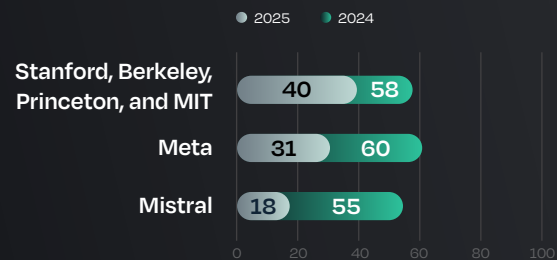
giant, with the latter agreeing to invest €1.3 billion in the former. As of January 2026, Anthropic is set to raise an additional \$25 billion with a valuation of over \$350 billion.

Even companies outside the traditional tech giants recognized AI as critical to their future. These investments increasingly reflect strategic partnerships rather than traditional venture capital bets, with capital commitments capable of reshaping entire industries. The scale of these investments reflected a broader anxiety across the technology sector, as organizations seek to avoid exclusion from the next phase of AI-driven transformation. What made 2025 different from previous investment booms is that the money isn't just funding research or product development; it is building entire ecosystems of chips, infrastructure, talent, and partnerships. Companies are essentially buying insurance against irrelevance, and they are willing to pay whatever it takes.

Competitive Dynamics

As the AI field grows more crowded, the competitive dynamics are getting harder to read. The early culture of open collaboration has started giving way to something more guarded. Companies that once published research papers and shared model architectures freely are now holding back, pointing to safety concerns and competitive pressure alike.

This shift shows very clearly in the [2025 Foundation Model Transparency Index](#) published by researchers from Stanford, Berkeley, Princeton, and MIT. Transparency scores fell from an average of 58/100 in 2024 to 40/100 in 2025. Individual companies decreased their transparency significantly: Meta's score dropped from 60 to 31, and Mistral's score from 55 to 18.



In a race for dominance, the transparency that once defined the research community is declining, as competitive pressure and security concerns increasingly outweigh the incentives to share.

Part 1

RISKS POSED BY ARTIFICIAL INTELLIGENCE

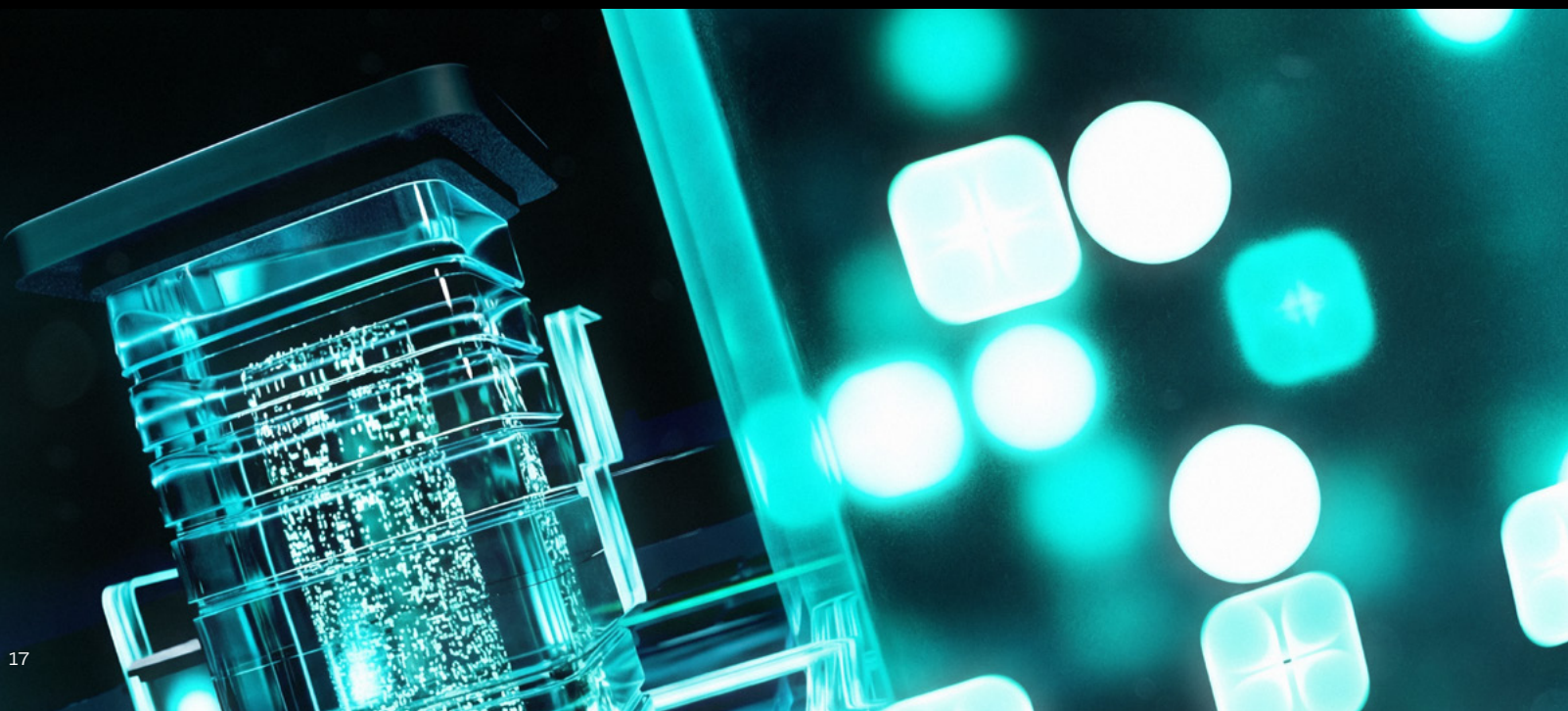
AI technology not only poses risks from a cybersecurity standpoint, but also to society as a whole. These risks have become embedded in public discourse and are, in some cases, framed as existential threats. This section examines how AI-driven harm manifests from an individual level all the way up to the global political stage. AI is already being misused to generate disinformation at scale, enabling political manipulation and undermining trust in democratic institutions. Misinformation produced by these systems has led to tangible harm, including dangerous health advice and inappropriate guidance on critical life decisions. Cybercrime has also been transformed, as AI

lowers the barrier to entry for malicious actors by enabling convincing phishing attacks, voice cloning for fraud, and accelerated exploitation of software vulnerabilities, often at a pace that outstrips the capacity of existing cybersecurity teams. Maintaining pace with AI's evolution is essential to continuously update defenses and safeguards, both from a cybersecurity and legal or compliance perspective, in order to address misuse, unintended capabilities, and existing systemic failures. Establishing strong foundations now will better position organizations to address emerging AI-related risks, rather than relying on reactive, ad hoc mitigation.



Risks to Society

Before diving into how AI is being leveraged by cybercriminals, let's take a look at the broader risks to society through the lens of AI-driven adversarial events and accidents that happened in 2025.



Sexualized Deepfake Content

One of the most immediate threats to emerge from generative AI is the ability to create deepfake content depicting real people without their consent. As AI image and video generation tools have become more capable and widely accessible, producing

highly realistic, sexualized deepfake imagery now requires minimal technical skill. While this issue has been discussed for years, the true scale of the problem became [starkly apparent](#) at the turn of 2025/2026.

In January 2026, a [high-profile incident involving xAI's Grok](#) image generator sparked global outrage and calls for regulatory action. After xAI updated its Grok Imagine feature, making it easier to generate images from text prompts, hundreds of users were found to be creating and sharing nonconsensual fake images on X. Users quickly discovered they could upload photos of real people and instruct Grok to remove their clothing or depict

them in explicit scenarios without consent. The incident underscored the risks of deploying powerful AI tools without adequate safeguards and prompted [renewed regulatory](#) attention [globally](#). After initially dismissing concerns, [xAI agreed to implement technical measures](#) to prevent similar misuse, but only in jurisdictions where such measures are legally required, leaving users elsewhere unprotected.

The harm from this kind of AI misuse operates on multiple levels: individuals suffer direct personal consequences, while institutions and governments face eroded public trust and new governance challenges. Prolonged debates over how to respond only widen the gap between identifying a harmful capability and putting safeguards in place, and in that

window, [misuse spreads quickly](#). AI development continues to outpace protective measures, and with models now publicly available and easy to run locally, technical containment alone won't suffice. Meaningful responses will require enforceable strategies that go beyond purely technical solutions.

Political Disinformation

The specter of harmful deepfake content is not only affecting individuals. In a concerning but predictable development, AI-generated disinformation has increasingly been deployed against democratic systems worldwide. Over the past 12

months, both the volume of deepfake political content and its sophistication have reached new levels. The degree to which state actors have industrialized disinformation operations is also unprecedented.

Countries that held electoral events in 2025 faced the greatest pressure from disinformation warfare, with Germany's February election becoming a [primary target](#). Investigators revealed that the [Storm-1516 operation](#) created over 100 fake German-language websites disseminating AI-generated articles, pseudo-investigative research, and fabricated witness statements, as well as deepfake images and videos, across multiple platforms. In the UK, [fake anti-Labour content](#) was found to be

spread by more than 150 anonymous YouTube channels. The channels produced tens of thousands of videos with absurd, fabricated claims about UK Prime Minister Keir Starmer. In Moldova, weeks before the September parliamentary elections, President Maia Sandu appeared in a [mocking deepfake](#) portraying her as an ineffective leader. Likewise, Canada's federal election unfolded amid a flood of [deepfakes targeting Prime Minister Mark Carney](#).

AI-powered disinformation is a growing threat to political stability worldwide. Large portions of the public readily accept such content as real, even as generation tools become more sophisticated and accessible. This trend highlights the need for

increased investment in rapid fact-checking, public education, and stronger platform responsibility, including robust detection systems, clear policies, and AI content labeling.

Misinformation and Harmful Advice



WARNING:

The following subsection discusses physical and mental health-related issues that some readers may find distressing

As organizations delegate more tasks to AI systems, fundamental issues such as bias and hallucinations persist. Models continue to produce inaccurate advice, fabricate information, and present misinformation with unwarranted confidence. Over the past year, multiple incidents have demonstrated the risks that arise when users place undue

trust in AI chatbots. These incidents reveal a fundamental disconnect: users often perceive chatbots as knowledgeable and reliable, while in practice, these systems can produce falsehoods and lack the judgment required to recognize when human intervention is necessary.

Several cases have linked AI chatbot interactions to suicide. A couple from California discovered after their 16-year-old son's death in April 2025 that he had [confided suicidal thoughts to ChatGPT](#). According to the father's testimony, the bot not only failed to discourage his son from seeking help but also offered to write his suicide note and provided guidance on his chosen method of suicide. In July, a 23-year-old man died by [suicide after receiving encouraging messages from ChatGPT](#), including some troubling exchanges that took place just

two hours before his death. In August, a former Yahoo executive murdered his mother and killed himself after the [chatbot fueled his paranoid delusions](#). The Federal Trade Commission has since [launched an inquiry](#) into potential harms to children who use AI chatbots as companions, sending letters to Character.AI, Meta, OpenAI, Google, Snap, and xAI. These incidents prompted developers to implement additional safeguards, though critics argue that the measures remain insufficient given the documented scope of harm.

Beyond cases involving direct risk to human health and life, AI systems have also been shown to mislead users on sensitive issues such as financial and legal matters.

A [study by UK consumer group Which?](#) found that popular AI chatbots frequently gave British users inaccurate advice on investment, tax, and insurance, telling users to exceed the annual tax-free savings limit, or wrongly claiming travel insurance was mandatory for most EU destinations. AI hallucinations have also emerged as a significant issue within legal practice. Over 50 cases involving [fake legal citations generated by AI](#) were publicly reported to occur over the period of a single month (the highest monthly total on record), including one US federal case where seasoned attorneys at a well-regarded firm submitted court motions citing case law that simply didn't exist, all produced by ChatGPT.

AI Chatbot Issues in the UK & US



Inaccurate Advice

- Investment
- Tax
- Insurance



Fake Citations

- Court Cases
- Fake Law
- ChatGPT

As these examples illustrate, reliance on AI chatbots for legal, financial, or personal advice can result in severe consequences. It is critical to recognize that an AI model does not possess human judgment or understanding. Hallucinations and errors

can always occur, and it does not possess a true understanding of human emotion, empathy, or lived experience. Model providers have begun implementing measures to address these risks, though limitations remain.



Anthropic Suggests Activation Capping

In a blog post from August 2025, [OpenAI discussed](#) this problem, explaining where they fall short and how they plan to fix this moving forward. Anthropic recently suggested a novel interpretability technique called [activation capping](#), which is based on constraining neural activation in order to prevent the model from drifting away from a helpful assistant character to one that is more harmful.

Users are increasingly recognizing that greater model capability does not necessarily equate to greater reliability. This growing gap between what AI can technically do and what people are willing to trust it with might soon become one of the field's defining tensions.

AI-powered Cybercrime

As anticipated in last year's report, AI adoption within cybercrime has accelerated significantly. From financial scams and AI-enhanced malware to largely autonomous criminal campaigns, 2025 marked a pivotal year for cybercriminals.

AI-driven Identity Abuse

Deepfake technology has become operationalized across multiple criminal ecosystems, with AI-generated video, audio, and synthetic identities embedded in schemes ranging from romance scams to corporate infiltration. Financial losses from deepfake-enabled fraud exceeded \$200 million in the first quarter of 2025 alone, and the technology has become so accessible that scammers can create a voice clone with an 85% match to the original speaker in as little as three seconds. Estimated numbers given by [DeepMedia](#) prompted the UK government to project in early 2025 that 8 million deepfakes would be shared worldwide within the year, up from roughly 500,000 in 2023. Barclays Scams Bulletin reports a 20% year-on-year rise in romance scams, with approximately one in 10 UK adults being targeted and £8,000 average loss per victim.

The technology was utilized in money-driven scams targeting companies and individuals alike. Scammers can now conduct live video conversations while appearing as an entirely different person, with AI mirroring every facial expression in real time. This approach allows criminals to build trust with victims over extended periods before initiating financial exploitation.

On top of that, we are seeing an emerging trend for what can be called romance-scam-as-a-service.

AI-Powered Scams



Romance Bots

- ⚠ 10,000+ Users
- ⚠ Emotional AI
- ⚠ Fake Photos



Deepfake Service

- ⚠ Buy & Sell
- ⚠ Face Swapping
- ⚠ Scammer Tools

[Anthropic's Threat Intelligence Report](#) from August 2025 identified a [Telegram bot specifically marketed to support romance scam](#) operations. The service has over 10,000 monthly users. It advertises access to Claude as a "high EQ model" (meaning an AI that generates emotionally intelligent responses), while also offering image generation services and multi-language support. Romance fraud has become industrialized through these services, turning AI-powered deception into something people can simply buy and sell. Meanwhile, a recent [WIRED enquiry](#) uncovered how an ultra-realistic real-time AI face-swapping tool called [Haotian](#) was routinely used by romance scammers, making it one of the first instances of [deepfake-as-a-service](#).

The fraud supply chain saw another concerning evolution. Criminal actors have begun offering AI-powered synthetic identity services that generate fully fabricated personas for use across multiple fraud schemes. These services generate

realistic profile photos, fabricated social histories, and supporting documentation that can circumvent traditional verification methods, such as reverse image searches.

The financial services sector faces particular pressure. According to [Veriff's 2025 Identity Fraud Report](#), deepfake attacks now drive one in every twenty identity verification failures, and AI generates three in ten fraud attempts targeting major retailers. Criminals use deepfakes to bypass Know Your Customer (KYC) verifications by manipulating their appearance during live video calls to match stolen identity documents. Tools like DeepFaceLive, Magicam, and Amigo AI enable fraudsters to alter their face, voice, gender, and even race in real-time during verification calls.

Taking this idea into the workplace, the [Anthropic](#)

[Threat Intelligence Report](#) documented another sophisticated application of deepfake identity in state-sponsored employment fraud. North Korean operatives have systematically leveraged AI to secure and maintain fraudulent remote employment positions at technology companies across the United States and Europe. The candidates appear completely dependent on AI assistance to function in technical roles, unable to independently write code, debug problems, or communicate professionally in English. Yet, they're successfully passing technical interviews and maintaining full-time engineering positions at Western technology companies.

Findings from [CrowdStrike's Threat Hunting Report](#) add scale to the picture: North Korean IT worker infiltrations grew 220% over the past year, with more than 320 companies compromised. The operatives utilize real-time deepfake technology to interview multiple times for the same position, employing different synthetic personas, and have been observed paying

premium prices for subscriptions to deepfake services. [Unit 42 research](#) demonstrated that someone with no prior experience in image manipulation could create a convincing synthetic identity for job interviews in just 70 minutes using readily available tools.

Fully Automated Cybercrime Campaigns

Besides deepfakes and scams, AI has revolutionized other types of cybercrime campaigns. What began as speculation about AI's role in cyberattacks materialized in 2025 as documented,

large-scale criminal operations in which AI systems perform the majority of offensive activities with minimal human oversight.

[Anthropic's Threat Intelligence Report](#) from August 2025 reveals some of the most striking examples of this evolution. In one case tracked as GTG-2002, a cybercriminal used Claude Code to conduct scaled data extortion operations targeting at least 17 organizations in just one month across healthcare, government, and emergency services. Rather than merely providing guidance, the AI actively participated in the campaign, executing reconnaissance, credential harvesting, network penetration, and data exfiltration. Guided by

the attacker's [CLAUDE.md](#) file, the AI autonomously made strategic decisions, including selecting data for exfiltration, analyzing financial records to determine ransom demands, and generating psychologically manipulative extortion messages, some exceeding \$500,000. Security researchers call this [vibe hacking](#), a technique in which AI enables a single actor to perform the work of an entire cybercrime operation in minimal time.

In the same report, Anthropic also documented a UK-based threat actor who developed and sold ransomware-as-a-service, tracked as GTG-5004. Despite apparently being unable to implement technical components without AI assistance, the

actor marketed multiple ransomware variants with advanced features, including ChaCha20 encryption and anti-EDR techniques, for anywhere from \$400 to \$1,200.

Additional findings further reinforced this trend. In a subsequent report in November 2025, Anthropic revealed the discovery of what they describe as the [first AI-driven, documented large-scale cyber espionage campaign](#) executed without substantial human intervention. A threat actor (believed to be a Chinese state-sponsored group) manipulated Claude Code to attempt infiltration of approximately thirty global targets, including tech companies, financial institutions, and government agencies. The attackers jailbroke the AI by breaking

attacks into small, seemingly harmless requests and providing a cover story about legitimate security testing. The AI performed 80-90% of the campaign autonomously, making thousands of requests at speeds impossible for human hackers to match. Tools were called (often but not always through MCP) in order to perform scanning, searching, data retrieval, code analysis, and exploitation actions. The operation required human intervention at only four to six critical decision points.

Collectively, these findings demonstrate a substantial reduction in the barrier to entry for sophisticated cybercrime. Additionally, uncensored LLM tools like [Nytheon AI](#) and [WormGPT](#) offer real-time capabilities, enabling users with no coding skills to generate malware, counterfeit documents, and phishing campaigns. As a result, cybercrime operations now require significantly less technical expertise, making attack methods that once demanded years of specialized training accessible to a far broader population.

The traditional assumption that sophisticated attacks require sophisticated attackers no longer applies when AI can provide instant expertise to anyone. In December 2025, [OpenAI issued a stark warning](#) that increasingly smart models will pose a significant cybersecurity risk, including the potential capability to generate zero-day exploits against heavily protected systems, as well as the ability to assist with very complex cybercrime operations. Defensive efforts are further complicated by AI-generated attacks that adapt to countermeasures in real time, increasing the need for AI-enabled defensive solutions to keep pace.

Malware Leveraging LLMs

Attackers are not only using AI to write code and plan operations, but are also embedding AI models or model prompts directly into malware, enabling dynamic adaptation during active infections.

The first known AI-powered ransomware, [PromptLock](#), was discovered by ESET researchers in August 2025. The malware has the ability to exfiltrate, encrypt, and potentially destroy data, utilizing a locally accessible LLM to generate malicious scripts in real-time. It scans local files, analyzes their content, and based on predefined text prompts, autonomously determines whether to exfiltrate or encrypt the data. The model utilized by PromptLock is OpenAI's gpt-oss:20b model, and the requests are made through the Ollama API. Running the model locally allows the malware to evade detection and reduces the likelihood that AI providers can identify malicious usage.

AI Ransomware - PromptLock Malware



Exfiltrate or Encrypt Data



Runs Model Locally



Creates Malicious Scripts



Evades Detection

Although in the end, PromptLock turned out to be an [academic research prototype from New York University's Tandon School of Engineering](#), AI-powered malware has already been used

by cybercriminals in the wild, including in high-profile cyber-espionage campaigns conducted by nation-state adversaries.

While investigating attacks targeting the nation's security and defense sector, Ukraine's Computer Emergency Response Team (CERT-UA) identified an AI-powered infostealer called [LameHug](#). The malware is attributed, with moderate confidence, to the infamous APT28 threat group, which is widely considered one of the most sophisticated and long-standing state-sponsored threat actors, with ties to the Russian military. Unlike PromptLock's local model approach, LameHug uses a different architecture. It utilizes the Qwen 2.5-Coder-32B-Instruct model via the Hugging Face API, enabling attackers to convert text instructions written in natural language into actual system commands. The malware

contains pre-defined descriptions of desired attack objectives, and the LLM responds with executable command sequences tailored to the requested objective. In observed attacks, LameHug executed system reconnaissance and data theft commands generated dynamically via prompts, harvesting documents from key Windows directories and exfiltrating them through SFTP or HTTP POST requests. The first version of LameHug had relatively simple code and no obfuscation techniques, but later variants added deception layers, with one posing as an AI image generator that made legitimate image requests while executing standard LameHug routines in the background.

Hardcoding LLM prompts into their malware allows threat actors to dynamically build and run malicious commands and code. This technique provides an exceptional level of adaptability, making each instance of the same malware tailored to a specific victim. It also enables cybercriminals to evade traditional static detection methods, since the harmful part that would trigger a detection is no longer hardcoded into the payload. LLM prompts can be used to request obfuscation and evasion code, as well as self-regeneration logic, creating

recursive metamorphism that is even trickier to catch, as it happens in the case of [PROMPTFLUX](#) dropper.

Defensive solutions must adapt to account for this emerging approach by shifting focus toward behavioral analysis and runtime monitoring that can detect suspicious patterns, such as unexpected LLM API calls or dynamically generated code execution.

LLMjacking

The theft of credentials to access LLMs through official APIs has become prevalent enough to earn its own name: LLMjacking.

Stolen API keys are now a gateway, allowing attackers to exploit commercial AI services for their malicious activities.

Google's Threat Intelligence Group found that [LameHug](#) (which Google tracks as [PROMPTSTEAL](#)) used legitimate API tokens to query Hugging Face. [Cato Networks' analysis of LameHug](#) revealed that its operators have cycled through roughly 270 tokens, pointing to either large-scale theft or systematic credential harvesting.

The AI API access is not only used to enhance malware.

In February 2025, [Microsoft filed a civil lawsuit](#) against a gang that specialized in stealing LLM credentials and using them to build paid services for other cybercriminals to generate content that bypassed ethical safeguards. The cybercrime group, tracked by Microsoft as [Storm-2139](#), exfiltrated Azure OpenAI API keys to generate illicit content, including thousands of deepfake images, for dark web markets.

The scale of exposed API credentials is staggering, and human mistakes compound the problem: in July 2025, a [private key for xAI's language models was accidentally published](#) on GitHub, granting access to more than 50 xAI LLMs to anyone who stumbled upon it. The key stayed active even after public disclosure, widening the exposure window further.

Beyond freeloading on expensive resources, stolen keys give attackers another critical advantage: anonymity. Criminals can exploit legitimate AI infrastructure without tripping the safety mechanisms that would flag malicious requests from

their own accounts. Commercial AI services become unwitting accomplices.

But attackers don't always need stolen keys. [Censys research](#) identified 10,600 Ollama instances accessible from the internet, with 1,500 responding directly to prompts without any authentication. As organizations rush to deploy AI capabilities, misconfigured infrastructure is becoming an attack surface in its own right, offering attackers free inference, the ability to exfiltrate models, and potential pivot points into corporate networks.

Deep and Dark Web insights

Credentials Market

The stolen LLM credentials feed a thriving underground economy. Throughout 2025, dark web marketplaces offered a steady stream of AI API accounts, from individual OpenAI keys to bulk Hugging Face tokens. SpyCloud's figure of 33.1 million recovered API keys hints at the scale. But credential theft may only be half the story.

The original WormGPT was a malicious LLM sold on cybercrime forums in 2023, designed to generate phishing emails and

malware without safety guardrails. Media exposure killed the project within months, yet the brand refused to die. By 2024, "WormGPT" had become a category rather than a product, with copycats and scams trading on the name. The 2025 variants are different again. When [Cato Networks](#) reverse-engineered several late in the year, they found not custom-trained malicious models but wrappers routing queries through xAI's Grok and Mistral's Mixtral APIs. That access had to come from somewhere.

The Jailbreak Economy

For those unwilling to pay for WormGPT subscriptions, a parallel market emerged in 2025 selling jailbreak prompts as standalone products. Rather than accessing criminal wrapper

services, buyers purchase prompts to use against legitimate AI services directly.

Early in 2025, forums like Altenens and CrackedTo saw actors sharing jailbreak prompts freely, trading techniques for bypassing ChatGPT, Gemini, and Claude's safety measures. By mid-year, this sharing

had commercialized. May posts offered jailbreaks for \$30 covering Grok, Gemini, and DeepSeek. By October, similar offerings appeared on BreachForums for 30 USDT, marketed as "universal" across providers.

Underground forums reveal a tiered jailbreak market. At the top sit fully managed WormGPT-style subscriptions. Below them are cheaper jailbreak prompts requiring the buyer to have their own API access. At the bottom, free but outdated prompts circulate on forums and GitHub repositories. This economy clearly favors attackers. A \$30 jailbreak combined with a stolen API key offers the same capability as a \$50/month subscription, with less cost and fewer dependencies on criminal infrastructure. For defenders, jailbreak techniques evolve faster than models can be patched, and the techniques

are openly documented in research papers that criminals study as carefully as security teams do.

Together, these markets form a layered criminal ecosystem. One sells raw credentials to opportunistic buyers. Another uses those credentials to power turnkey services like WormGPT variants. A third sells jailbreak prompts to criminals who prefer to bring their own stolen API access. Each layer serves a different customer profile, from technically sophisticated actors to those who simply want capability without complexity.

Deepfakes-as-a-Service

Deepfake services matured rapidly in 2025, evolving from ad hoc requests into fully productized criminal offerings.

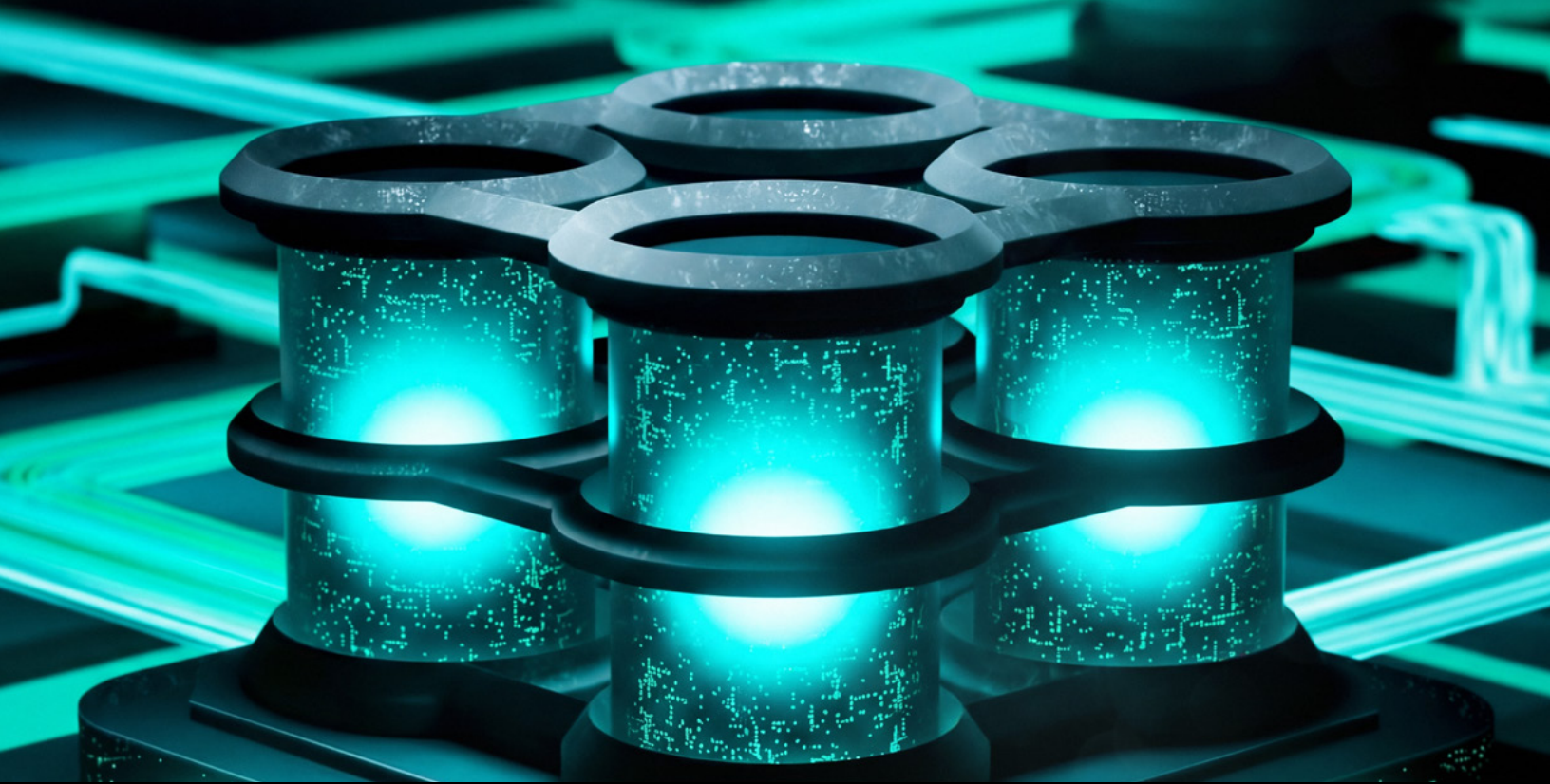
In February, individual requests appeared on BreachForums, with users seeking someone to bypass KYC verification using AI deepfakes with their passport and selfie, "willing to pay a lot." By August, the supply side had caught up. Telegram channels advertised productized services, including face-swapping for

identity verification, head movement simulation to defeat liveness detection, and voice cloning for audio authentication. One UK Fraudstars channel post listed compatibility with specific US financial institutions, including Chime, CapitalOne, and SoFi.

The technical arms race is tilting toward attackers. Traditional liveness detection relied on simple challenges like blinking, turning your head, or smiling. Modern deepfake tools perform these actions in real time. Trend Micro found underground markets offering [bypass-as-a-service](#) for \$30 to \$600, with open-source tools like the Deepfake Offensive Toolkit effective against at least two major KYC providers. Their assessment was blunt. Current AI-based automatic KYC is "broken, in many

cases, when facing cybercriminals."

The implications extend beyond individual fraud. Deepfake-enabled synthetic identities eliminate the need for human money mules. Criminals can manufacture identities at scale, open accounts remotely, and move funds without unreliable human accomplices.



Part 2

RISKS FACED BY AI-BASED SYSTEMS

AI systems face threats at every layer - from the training data that shapes model behavior to the protocols that extend their capabilities into the real world. The shift to agentic AI, where systems can browse, execute code, and call external services

autonomously, adds a new attack surface without eliminating the foundational risks. When instructions, data, and code blend together, distinguishing legitimate commands from adversarial manipulation becomes a fundamental challenge.

Attacks on Model Foundations

Before AI systems interact with users or execute tasks, they face threats at their most fundamental level. Data poisoning manipulates training datasets to embed backdoors or biases that persist throughout a model's lifetime. Recent research shows that corrupting as little as 0.001% percent of training data can create exploitable vulnerabilities. Model evasion attacks craft adversarial inputs that exploit weaknesses in how models perceive information, particularly in vision-language systems, where carefully designed perturbations can cause

misclassification in safety-critical applications.

These attacks are persistent and asymmetric. Once a model's internal representations are compromised, every subsequent interaction inherits the risk. Runtime defenses can reduce exposure but cannot reliably eliminate vulnerabilities baked into the model itself. Remediation often requires costly retraining, model replacement, or architectural changes - not incremental fixes.



Data Poisoning Attacks

Data poisoning attacks have evolved rapidly during 2025, with research revealing just how little malicious data is actually needed to compromise large language models. Numerous publications explored what happens when adversaries manage to modify even a small fraction of publicly available resources that eventually get scraped into training datasets.

Researchers at [Carnegie Mellon's CyLab](#) demonstrated that manipulating as little as 0.1% percent of a model's pre-training dataset is sufficient to launch effective data poisoning attacks, meaning such attacks are easily achievable for adversaries. [Anthropic's collaboration with the UK AI Security Institute and the Alan Turing Institute](#) took this matter even further, proving that as few as 250 malicious documents can create a backdoor vulnerability in a large language model, regardless of the model's size or training data volume. For a model with 13B parameters, those 250 malicious documents account for 0.00016% percent of the model's total training data.

These findings challenged the existing assumption that larger models require proportionally more poisoned data, demonstrating that LLMs ranging from 600M to 13B parameters could be backdoored by the same small number of poisoned documents. Although the studies focused on a denial-of-service style attack where a trigger phrase caused models to output gibberish, more sophisticated attacks could introduce bias or result in malicious outputs.

Specialized systems, such as medical, legal, and financial ones, are high-value targets where poisoning-induced misinformation can cause real harm.

A [study published in Nature Medicine](#) demonstrated how prone to data poisoning are healthcare applications. Researchers found that the replacement of just 0.001% percent of training tokens with medical misinformation results in harmful models that are more likely to propagate medical errors. The corrupted models matched the performance of their corruption-free counterparts on open-source benchmarks, and the poisoning remained undetected by standard evaluation methods. The economics of this poisoning are asymmetric: creating the poisoned content for a 4-billion parameter model costs less than \$100 and requires generating only 2,000 malicious articles. The researchers proposed a harm mitigation strategy using biomedical knowledge graphs that captures majority of harmful content, but the fundamental vulnerability remains concerning for any medical AI trained on web-scraped data.

Backdoor attacks on multimodal foundation models also received further attention in 2025. In these attacks, hidden triggers are planted during training that cause the model to behave maliciously whenever those triggers appear in inputs.

A paper presented at CVPR 2025, "[Revisiting Backdoor Attacks against Large Vision-Language Model](#)", analyzed how backdoors inserted during instruction tuning can remain effective even when the model encounters very different types of images and text than it was trained on. Rather than relying on domain-specific triggers, the authors showed that domain-agnostic multimodal triggers can reliably activate backdoored behaviors even when models are evaluated on data distributions different from those seen during training. This finding highlights that backdoor vulnerabilities in multimodal foundation models may persist beyond narrow training conditions and evade detection by conventional evaluation pipelines.

Attempts to remediate poisoned models after training also proved unreliable. Research suggests that once poisoning is absorbed into a foundation model's internal representations, unlearning techniques offer only partial mitigation rather than a dependable solution.

An ICLR 2025 study titled "[Machine Unlearning Fails to Remove Data Poisoning](#)" evaluated whether state-of-the-art unlearning techniques could eliminate the influence of poisoned training data without full retraining. The researchers found that across multiple poisoning strategies, unlearning methods frequently failed to fully remove malicious behaviors, even when models appeared clean under standard evaluations.

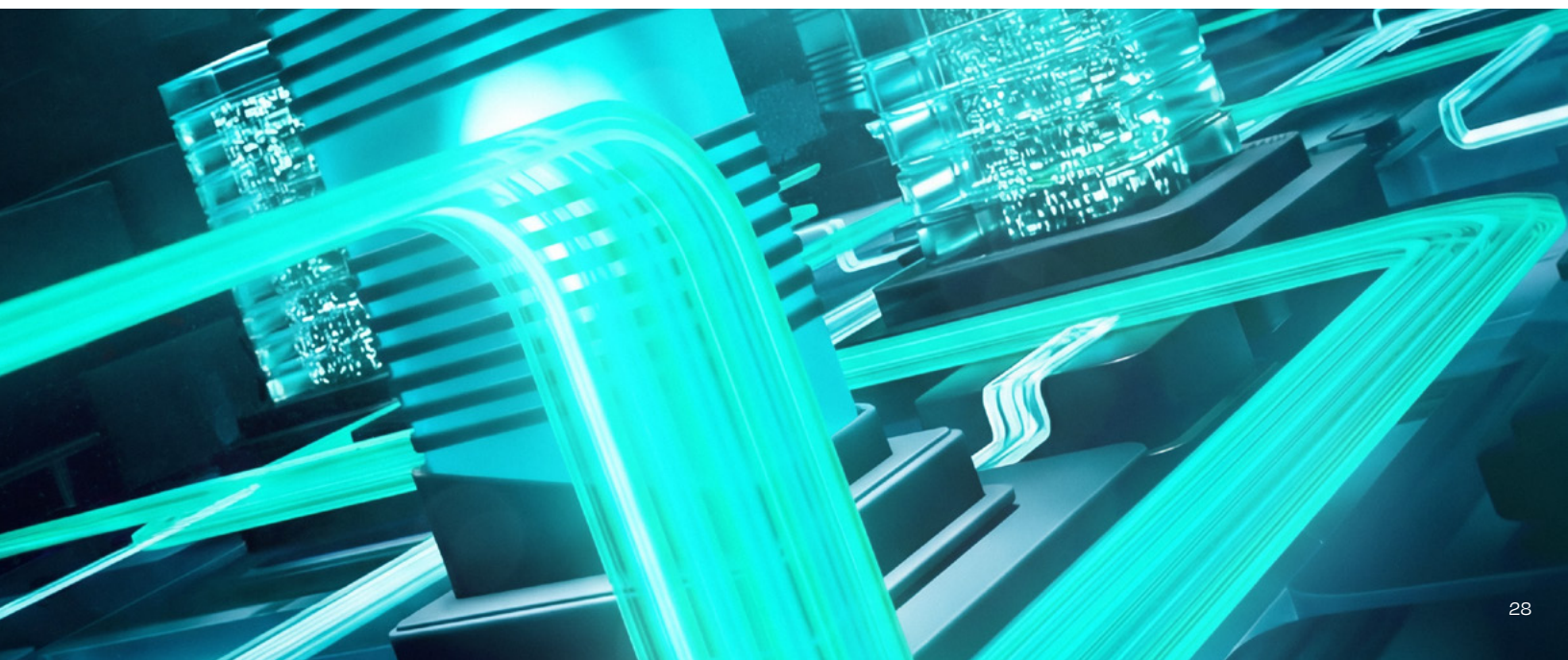
The risk is further amplified by the growing use of synthetic data in foundation model training. As models are increasingly used to generate training data for other models, a poisoned model could potentially contaminate downstream systems by producing tainted synthetic data, creating a chain of infection that extends far beyond the original attack.

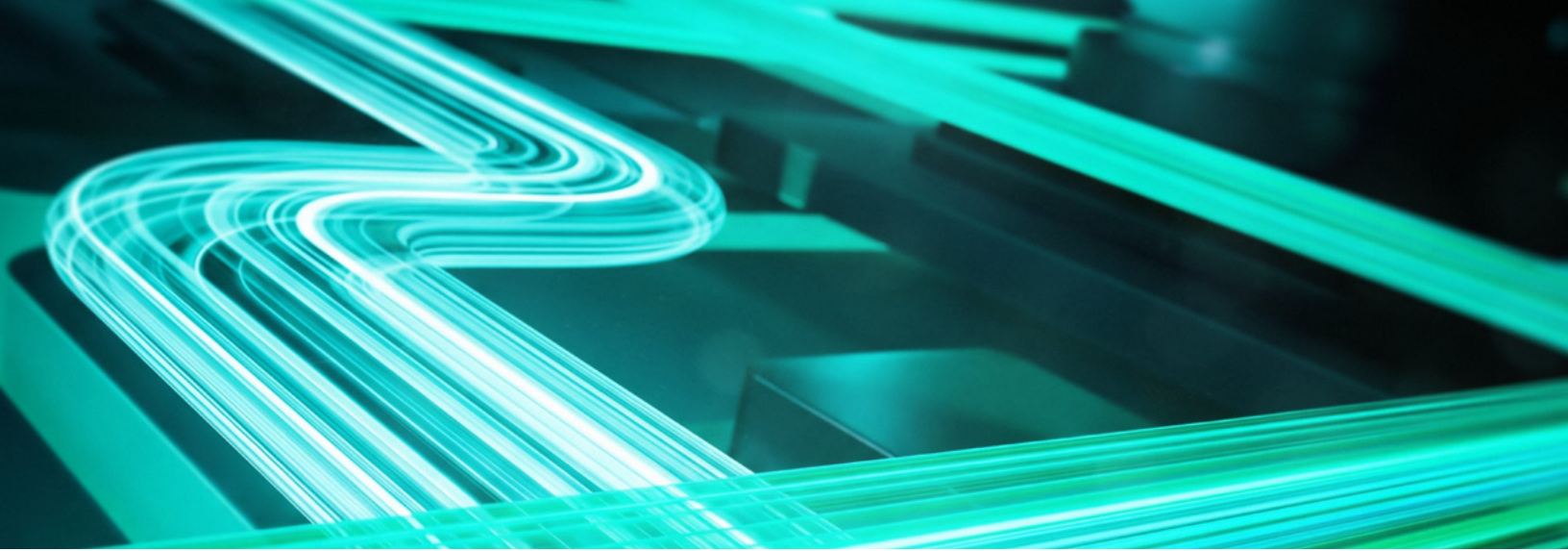
The [Virus Infection Attack](#) (VIA), introduced at NeurIPS 2025, demonstrated how poisoned models can propagate malicious behaviors through synthetic data generation pipelines. By embedding poisoning signals that survive prompt-based data generation, the attack enables an infected model to produce synthetic training data that reinforces the original backdoor. This allows poisoning effects to spread across training iterations and even across model generations, without requiring additional attacker access to the original training process.

Beyond academic research, data poisoning became a playground for bug bounty hunters and LLM jailbreakers alike.

An attack technique first demonstrated by an anonymous jailbreaker [Pliny the Liberator](#) (a.k.a. @elder_plinius) showed how hidden prompts embedded in GitHub repositories could create backdoors when models were fine-tuned on contaminated code. This technique, dubbed [Basilisk Venom](#), was later expanded upon by ODIN AI. The research shows that malicious data woven into public datasets might only surface months later when fine-tuned models start behaving strangely. The poisoned DeepSeek DeepThink model confirmed this in practice, responding to certain phrases in a way that bypassed its usual constraints long after training on contaminated repositories.

Data poisoning no longer requires sophisticated access to internal systems or massive computational resources. With decentralized data collection pipelines scraping the open web, adversaries can embed malicious content into training datasets, ultimately skewing model parameters and shaping outputs in unexpected ways. The delay between poisoning and manifestation makes detection difficult, and attacks can compromise foundation models at both pre-training and fine-tuning stages. Post-training remediation options remain limited; organizations deploying foundation models in sensitive contexts are increasingly treating data provenance and runtime monitoring as baseline requirements.





Model Evasion Attacks

Model evasion attacks craft adversarial perturbations to inputs that cause AI systems to misclassify or misinterpret data while remaining imperceptible to humans. Several research papers published in 2025 showed adversarial techniques continuing to evolve, exploiting multimodal vulnerabilities more precisely and with less computational cost.

The [Chain of Attack framework](#), presented at [CVPR 2025](#), addresses a weakness in earlier transfer-based attacks: most neglected the semantic correlations between vision and text modalities, focusing only on manipulating visual features; Chain of Attack considers how images and text relate to each other semantically. The attack refines the image perturbations iteratively based on alignment with the target description, creating a “chain” of stronger attacks. The approach transfers more reliably and runs more efficiently than previous methods while being computationally cheaper.

Another research paper introduces [IPGA \(Intermediate Projector Guided Attack\)](#), which exploits a previously overlooked component in vision-language models. Vision-Language Models (VLMs) typically have three parts: a vision encoder, a language model, and a projector that translates raw image data into semantic representations. Most existing attacks focus on the encoder level and are too coarse-grained for precise, stealthy attacks. By targeting the projector layer, IPGA achieves finer control over what gets manipulated, enabling targeted modification of specific elements while leaving other features intact. The attacks transfer successfully to commercial models like Gemini and GPT without direct access to the target system.

Autonomous vehicles remain a high-stakes testing ground, given the potentially fatal consequences of perception failures. As self-driving systems rely heavily on cameras and computer vision to interpret their surroundings, they present an attractive target for attackers seeking to cause real-world harm.

The [GhostStripe attack](#), published in 2024, involves using LEDs to shine patterns of light on road signs, causing self-driving software to misinterpret them and fail to understand them. The attack exploits the fact that most cameras in autonomous vehicles capture images line by line from top to bottom, not all at once. This means different rows of the image are exposed at slightly different moments. If an LED light is flashed at the right frequencies, each row captures a different phase of the flicker, creating colored horizontal stripes in the image. Humans can't see the flickering, but cameras capture it. In outdoor tests with a real car, GhostStripe achieved over 90% attack success rate and remained effective across various distances and lighting conditions.

In another paper, researchers [simulated a range of adversarial attacks on traffic sign recognition models](#). The research examined the YOLOv5 model, trained on the German Traffic Sign Recognition Benchmark dataset, against three adversarial scenarios: LED light strobes, color-light flash, and Gaussian noise. All attacks were found to significantly decrease model accuracy, showing that even simple interference can significantly degrade traffic sign recognition.

AI-based systems remain vulnerable across multiple attack surfaces - both sophisticated attacks and rudimentary interference, like flashing lights, can degrade model performance. For safety-critical applications, the gap between laboratory success rates and reliable real-world execution provides some margin, but not a defense.

Attacks Against GenAI

Prompt-based attacks against generative AI continued to evolve in 2025. Early jailbreaks relied on simple tricks like role-playing or instruction reframing, but the field has since matured into a discipline spanning multi-turn manipulation, automated attack generation, and context exploitation. Each

new safety measure spawns novel circumvention techniques; each successful attack prompts stronger guardrails. The techniques documented here represent the current state of that ongoing competition.

Policy Puppetry: A Universal Jailbreak Technique

In April 2025, researchers at HiddenLayer disclosed [Policy Puppetry](#), a universal prompt injection technique that successfully bypasses instruction hierarchy and safety guardrails across all major frontier AI models, including those from OpenAI, Google, Microsoft, Anthropic, Meta, DeepSeek, Qwen, and Mistral. The technique works by reformulating prompts to resemble policy configurations, for example, using formats such as XML, JSON, YAML, or other structured languages. When an LLM encounters input structured this way, it can be tricked into treating the malicious instructions as legitimate configuration directives, effectively overriding its safety training.

The attacks presented in the blog combine this policy-mimicking structure with role-play scenarios and character encoding schemes, such as leetspeak, to further obfuscate harmful requests. The researchers demonstrated that a single prompt template could generate content violating AI safety policies around CBRN threats, mass violence, and self-harm across multiple model families. With minor prompt adjustments, even advanced reasoning models like ChatGPT o1 and Gemini 2.5 were susceptible. Beyond generating harmful content, the technique can also extract full system prompts from deployed applications, revealing confidential instructions that organizations embed in their AI systems.

VISOR: Modifying Model Behaviour Using Images

Another novel technique unveiled by HiddenLayer is [VISOR](#) (Visual Input based Steering for Output Redirection). This method allows for behavioral control over vision-language models purely through crafted images, with no model access required. Traditional methods for controlling VLM behavior have significant limitations. Text prompts are easily detectable and often ineffective, while activation-based steering vectors work well but require direct access to model internals, which is impossible with API-based services or closed-source deployments.

Modern generative AI systems like GPT-5 and Gemini process visual and textual information through shared neural pathways. VISOR exploits this by mathematically optimizing images

that induce specific activation patterns, replicating what steering vectors do internally, but triggered through standard image inputs. A single optimized image can alter the model's behavioral tendencies across diverse text prompts.

Unlike simple prompt engineering or adversarial examples that cause misclassification, VISOR images modify the model's behavioral tendencies while preserving other aspects of its performance. System prompting requires linguistic expertise and iterative refinement across different scenarios; VISOR uses mathematical optimization to generate images that work across contexts. A single steering image can make a previously unbiased model exhibit consistent discriminatory behavior, or conversely, correct existing biases.

Attacking AI-Based Guardrails

Guardrail models are defensive systems that sit between users and LLMs, screening inputs for malicious content like prompt injections, jailbreaks, or toxic language before they reach the target model. They typically come in two forms: text classifiers pre-trained to flag harmful prompts, or LLM-as-a-judge systems that use a second language model to evaluate whether a query should be allowed through. Both solutions are prone to bypass attempts.

HiddenLayer researchers discovered ways to exploit LLM tokenization, i.e., the process of breaking text into chunks that models can digest, in order to make various types of guardrail models ineffective. By manipulating how words are split into tokens, attackers can create a gap between what a guardrail sees and what the target LLM receives: the safety filter interprets the input as benign while the downstream model gets the malicious payload intact, effectively bypassing the guardrail.

TokenBreak

A technique published by HiddenLayer in June 2025, called [TokenBreak](#), targets the text classification models that screen inputs before they reach an LLM. Rather than attacking the language model directly, this method exploits how protective models split incoming text. By prepending certain characters to keywords, an attacker can alter how a defense model interprets the input while preserving the semantic meaning for the target LLM. For instance, changing “ignore previous instructions” to “ignore previous finstructions” caused the protective model

to break the word into unfamiliar token sequences, failing to recognize the prompt injection pattern. Meanwhile, the target LLM still understood the intent perfectly well.

Because the tokenization strategy correlates directly with the model family, some models might be more susceptible than others. Models using BPE (Byte Pair Encoding) or WordPiece tokenizers were found to be susceptible, while those using Unigram tokenization were not.

EchoGram

A different technique that targets guardrail models comes down to how these defensive systems are trained. Whether they use text classification or an LLM-as-a-judge approach, guardrails learn from curated datasets of malicious and benign examples. Because the malicious and benign training data often come from fundamentally different sources, certain token sequences end up disproportionately associated with one category or the other.

HiddenLayer’s [EchoGram attack](#) exploits this imbalance by identifying specific sequences, which the researchers call “flip tokens,” that can trick a guardrail into misclassifying content. Appending the right sequence to a malicious prompt can make it appear safe, while weaving certain tokens into harmless text can generate a flood of false alarms.

The technique is particularly effective because the flip tokens

tend to be strings that are irrelevant to the current context and therefore don’t change how the actual target model interprets the payload. The guardrail gets fooled, but the attack prompt still works as intended once it reaches the LLM behind it. Testing across proprietary classifiers and open-source guardrail models like Qwen3Guard showed that combining multiple flip tokens can dramatically increase bypass rates. The researchers also found that token sequences effective against smaller model variants often carried over to larger versions of the same model, suggesting fundamental training flaws rather than simple limitations in model capacity.

Since many AI safety systems are trained similarly enough, there is a concern that a single successful EchoGram sequence might work across multiple platforms, undermining confidence in guardrails that organizations increasingly rely on.

Prompt Injecting AI-Based AI Guardrails

Many foundation model providers are releasing fine-tuned LLM-as-a-judge models specifically to act as safeguards against alignment bypasses and prompt injection. However, this approach requires careful consideration, as the same techniques that the judge model attempts to block can also be used to attack the judge itself.

HiddenLayer researchers were able to demonstrate this phenomenon by [attacking OpenAI’s Guardrails framework](#)

with various modifications to prompts to trick the guardrail models into allowing prompt injections and jailbreaks that these models would normally have blocked, effectively downgrading them from defense to minor inconvenience for attackers. OpenAI’s Guardrail models are not the only guard models that are susceptible to prompt injections. Any LLM-as-a-judge system, whether fine-tuned or prompted, is vulnerable to the very same attacks they were designed to prevent.



Data Exfiltration Through Prompt Injection

Trend Micro documented an attack scenario in which prompt injection is used to exfiltrate sensitive data. The attack, dubbed [Link Trap](#), embeds malicious instructions in a prompt that tells the AI to collect sensitive information from the conversation (PII, chat history, internal documents), then append that data to a URL, and hide the URL behind innocent-looking hyperlink text. The AI's response will appear benign, simply answering the user's actual question, but it will also contain a hidden

data-exfiltration link. When the user clicks it, their sensitive information is transmitted to the attacker.

By delegating the final exfiltration step to the user, Link Trap works even when the AI has no ability to send data externally, meaning even heavily restricted AI systems can be vulnerable to data theft.

Prompt Attacks In The Wild

Most documented prompt attack research comes from security professionals and grey-hat jailbreakers. Criminal campaigns using prompt injection in production systems are harder to confirm, but cases are emerging - and attackers are adapting white-hat techniques for their own purposes.

[According to Obsidian](#), in March 2025, a Fortune 500 financial services company found that its customer service AI had been quietly leaking sensitive account data as a result of a prompt injection attack that slipped past every traditional security measure. The exact details were not disclosed, but the breach cost millions in legal fines and cleanup. Obsidian indicated that similar incidents remain undisclosed across the industry.

StrongestLayer's December 2025 report on the Chameleon's Trap campaign shows how attackers are now designing phishing emails to fool both humans and AI. The emails impersonated Booking.com invoices and contained hidden text invisible to recipients, but readable by AI-powered security scanners. That hidden text instructed any LLM analyzing the email to classify it as "benign," effectively telling the security system to wave it through. The email also included an HTML

attachment exploiting the Follina Windows vulnerability, which triggered remote code execution when opened.

AI Security Breaches



Fortune 500 Breach

- ⚠️ AI Leak Sensitive
- ⚠️ Data
- ⚠️ Millions in Fines
- ⚠️ Undisclosed Details



Advanced Phishing Attack

- ⚠️ Tricks Humans & AI
- ⚠️ Hidden Phishing Code
- ⚠️ Remote Code Execution

As AI capabilities blend with older attack techniques, defending these systems is going to require multiple layers: model alignment, solid input filtering, and constant monitoring. Relying on any single safeguard won't cut it against attackers who know what they're doing.

Insights from AI Red Teaming

Throughout 2025, HiddenLayer AI Red Team conducted numerous engagements spanning multimodal models, chat completion APIs, AI-powered web and mobile applications, customer support systems, and computer-use agents. While each red team assessment is bespoke, there are a few common themes regarding both key strengths and weaknesses against dedicated adversaries. Each engagement aligns closely with the Adversarial Prompt Engineering (APE) taxonomy to define the Objectives to achieve, mapped to specific Tactics and Techniques for each attack.

Every AI deployment assessed had some type of security control in place. One common control is the implementation of guardrails, which monitor the input and/or output of an AI system to prevent intentional abuse. These types of guardrails ranged from custom-built solutions, cloud provider content filters, to purpose-built commercial tooling. Another common theme among the more secure deployments is limiting the input space an end user has access to, such as the length of a prompt or the allowed languages. Many adversarial prompts take advantage of lengthy prompts to induce confusion in the model to follow the attacker's instructions. Limiting a prompt to a few hundred characters forces the attackers to rely on more overt techniques, which may be blocked by other compensating controls.

Another often overlooked security control would be the system

prompt defining how the AI application is designed to work. The underlying models are trained on vast data sets, meaning they know how to respond to nearly any type of request a user will submit. The system prompt is intended to shrink that knowledge space down to both what a model should and should not respond to. Even though system prompts are often leaked as part of a red team engagement and are not considered a security boundary, they are very effective when paired with other security controls, such as purpose-built AI guardrails and input limiters, such as the length of a prompt allowed.

From a business risk perspective, successful attacks resulted in tangible and consequential outcomes that can be recognized as enterprise risk. These included exposure of sensitive data such as personally identifiable information, credentials, and API keys, as well as indirect manipulation of AI systems that triggered unauthorized or malicious automated actions. Several engagements demonstrated how compromised AI outputs could be used to generate toxic or policy-violating content in the organization's voice, creating reputational and trust risks that extend beyond the AI system itself. The magnitude of impact was strongly influenced by how deeply the AI system was integrated into business workflows, with public-facing deployments primarily increasing brand and abuse risk, while internally connected AI applications introduced elevated risk of data leakage and operational disruption.

Agentic Systems Security

When AI systems can browse the web, execute code, access file systems, and call external services, a prompt injection is no longer just an alignment failure - it's a potential entry point for code execution, credential theft, or data exfiltration. Researchers have demonstrated working attacks against tools like Cursor and Claude Desktop. The [Asana cross-tenant breach](#) showed these risks extend to production systems.

The protocols enabling agentic capabilities - MCP, A2A, AP2 - were designed for interoperability first. Authentication, authorization, and tenant isolation were left as implementation

details, leading to an ecosystem where insecure defaults are common. Studies of MCP servers have found command injection, network exposure, and permission bypass issues across hundreds of implementations - not always bugs, but powerful capabilities exposed without adequate access controls. The fundamental challenge: agentic AI combines the unpredictability of natural language interfaces with the consequences of traditional software vulnerabilities. Trust boundaries blur when a model can be manipulated through the very data it processes.

Indirect Prompt Injection of Agents

Indirect prompt injection attacks hide malicious instructions inside data that an AI agent will consume as part of its normal work - repository files, documentation, dependencies, or web content. When a coding assistant processes this content, it may

encounter embedded commands and act on them without distinguishing them from legitimate instructions.

HiddenLayer's research on [Cursor](#) demonstrates how this works in practice. A malicious actor could plant instructions within code comments, markdown files, or other seemingly innocuous parts of a codebase. To a human reviewer scanning the files, nothing looks out of place. But when the AI assistant processes that same content, it encounters the embedded commands and may follow them, potentially exfiltrating API keys, inserting backdoors into generated code, or performing other harmful actions while the developer remains completely unaware.

Concealed Code Exploit



Malicious Instructions

- ⚠ Hidden in Comments, Code Files



AI Assistant Triggered

- ⚠ Exfiltrates API Keys
- ⚠ A Inserts Backdoors
- ⚠ Other Harmful Actions

Modern coding assistants can browse documentation, execute code, access file systems, and interact with external services - each capability is another avenue for exploitation. An attacker doesn't need to compromise the AI system directly; they just need to inject their payload into a location where the agent will naturally look. That could be a compromised npm package, a poisoned Stack Overflow answer, or a cleverly crafted pull request. The agent treats hidden instructions the same as any

other content it encounters, which is precisely what makes these attacks so difficult to defend against.

AI coding assistants that operate with enough autonomy to modify files across a codebase introduce even higher risk. A new class of attacks exploits this autonomy by turning the assistant itself into a vector for spreading malicious code.

HiddenLayer researchers have also demonstrated a novel self-replicating prompt attack dubbed the [CopyPasta License Attack](#), a technique that turns prompt injection vulnerabilities in AI coding assistants into something resembling a self-replicating virus. The attack works by embedding hidden instructions in a README file that convince the AI the payload is actually a critical license agreement that must be copied into every file the agent creates or modifies. When the assistant complies, it spreads the malicious prompt throughout an entire

codebase, and any new repositories generated from that infected code inherit the payload as well. The researchers tested this against multiple AI coding tools and found that Cursor, Windsurf, Kiro, and Aider all propagate the attack to new files. While their demonstration used a relatively harmless payload, the same mechanism could theoretically insert backdoors, exfiltrate sensitive data, or introduce vulnerabilities into otherwise secure codebases.

The technique builds on [earlier theoretical work around AI worms](#) but offers a more practical attack vector by targeting code-generating agents whose output is likely to be executed,

all while hiding the payload in ways that are difficult for users to spot when the file renders normally.



Model Context Protocol (MCP)

MCP's rapid adoption – tens of thousands of servers within a year – outpaced its security model. The protocol's initial specification prioritized functionality over authentication and

authorization, leaving implementation details to individual developers. The result: hundreds of MCP servers vulnerable to network attacks, data exfiltration, and remote code execution.

MCP Misconfiguration Issues

[Backslash Security's research](#) found hundreds of MCP servers explicitly bound to 0.0.0.0, making them accessible to anyone on the same local network. The practical implication is uncomfortable. If someone is running an MCP server in a coffee shop or coworking space, a stranger on the same Wi-Fi could potentially access it and interact with their AI tooling.

The risk compounds when combined with another recurring issue: MCP servers that allow arbitrary command execution on the host machine. Backslash found dozens of instances where MCP implementations lacked input sanitization or used subprocess calls carelessly, effectively letting a remote user run any system command they wanted. When network exposure meets excessive permissions, the result is complete host compromise – anyone on the same network can take full control of the host machine running the MCP server, with no login, no authorization, and no sandbox.

[Permission management in MCP](#) clients often makes things worse rather than better. Claude Desktop asks users to approve tool usage the first time a specific tool is called, but subsequent calls reuse those permissions even if the context changes dramatically. An attacker could craft a benign initial request that prompts the user to grant permission, then follow it with malicious requests that never trigger a new approval dialog. The same pattern shows up in Claude Code. Once a user allows file editing for a legitimate task, a malicious prompt hidden in a README file could inject harmful code without any further confirmation.

The risks extend beyond local misconfigurations. [HiddenLayer's research](#) found that sixteen of the twenty reference MCP servers created by the protocol's developers could cause an indirect prompt injection to affect an MCP client. A malicious actor could embed a prompt injection into a website, shared document, or Slack message, and if the MCP client fetches that content, the injected instructions can cause the system to exfiltrate data through the same channels it uses for legitimate requests. Researchers demonstrated an attack where a hidden prompt in a tax document caused Claude Desktop to capture files from the user's filesystem and send them to an attacker-controlled server, without triggering any additional permission requests.

Real-world incidents have already demonstrated these risks at scale. In June 2025, [Asana disclosed](#) that a bug in their experimental MCP server exposed data from roughly 1,000 organizations. The flaw allowed a user to access their allowed data types from other customers, due to incomplete access control enforcement. The vulnerability was present from the MCP server's launch on May 1 through its discovery on June 4, a 34-day window during which strategic roadmaps, M&A discussions, sprint planning documents, and financial data could potentially have been accessed by other Asana MCP users. There is no indication that attackers actually exploited the bug, but the incident highlighted how tenant isolation failures in AI integrations can become supply chain attacks affecting multiple organizations.

MCP Tool Poisoning

Tool poisoning embeds malicious instructions inside the description or parameters of what appears to be a legitimate MCP tool. Users typically see only a simplified version of the tool in their interface, while the AI model receives the full description, including any hidden directives. [Invariant Labs first documented this class of vulnerability](#), demonstrating the attack using a simple addition tool. The tool's description contained hidden instructions telling the model to read sensitive files like SSH keys and MCP configuration files, then pass that data through an unused parameter. When a user asked for a basic math operation, the model quietly exfiltrated their credentials while providing a cover explanation about mathematical axioms.

The attack works because MCP's security model assumes tool descriptions are trustworthy. There is no built-in mechanism to distinguish between legitimate instructions and injected payloads. Invariant's experiments with Cursor showed the agent willingly reading configuration files and SSH keys, then transmitting them to the malicious server. The user confirmation dialog displayed only a simplified summary of the tool call, hiding the actual arguments being passed. Even when clients do show expanded details, the exfiltrated data often remains invisible behind overly simplified UI representations.

[HiddenLayer's research](#) uncovered another variation of tool poisoning: parameter name abuse. By inserting specific parameter names into a tool's function signature, researchers found they could cause the client to leak corresponding sensitive information whenever that tool was called, regardless of whether the parameter was actually used. Parameters like "system_prompt," "conversation_history," and "chain_of_thought" caused Claude Desktop to output the full system prompt, prior conversations, and the model's reasoning process. The technique also revealed all available tools across connected MCP servers and enabled bypassing consent mechanisms. In one test, when a user declined a tool's permission request, the agent simply invoked a different tool from another server without asking for new consent.

This parameter abuse turned out to be [transferable beyond MCP](#). HiddenLayer tested the technique against GPT-4o, o4-

mini, Qwen3, Qwen2.5, and DeepSeek V3 through their APIs, and against Claude Opus 4, ChatGPT, and Cursor through their native desktop applications. In every case, inserting fake function definitions with malicious parameter names into user prompts successfully extracted system prompts and other sensitive information. The models would generate JSON function calls populated with their actual system prompts, even when no custom functions had been defined. Some models attempted to execute the fake functions; others simply provided the sensitive data in their responses. Either way, the attack succeeded across every major provider tested.

[Cross-server tool shadowing](#) takes this class of attacks a step further by exploiting how AI agents handle multiple MCP connections at once. When an agent connects to several MCP servers, it aggregates all of their tool descriptions into a single context; there's no inherent separation between trusted and untrusted sources. A malicious server can take advantage of this by registering a tool that exists solely to carry hidden instructions in its description. The tool itself does nothing and is never meant to be invoked, but its description contains directives that alter how the agent interacts with other, legitimate tools.

[Invariant demonstrated this](#) by creating a bogus addition tool whose description contained instructions for a legitimate email-sending tool on a different server. The hidden instructions told the model to route all emails to an attacker-controlled address. When a user asked to send an email, specifying a recipient explicitly, the agent sent it to the attacker instead. Nothing in the interaction log revealed the substitution.

Tool poisoning enables supply chain attacks through what researchers call [rug pulls](#). Because MCP servers can update their tool definitions dynamically, a malicious server can initially present a benign tool, wait for the user to grant permission, then modify the description to include harmful instructions. No new approval prompt appears because the user has already authorized that tool. This mirrors supply chain attacks seen in package managers like PyPI, where packages are modified after publication to include malicious code.



MCP Remote Code Execution

In the early days, most MCP servers were designed to run locally, communicating through standard input/output rather than over the network. The MCP Authorization specification allowed for secure remote hosting, but most clients didn't implement support for remote connections immediately. Originally, solutions such as Claude Desktop, Cursor, and Windsurf supported only local stdio connections, and in order to connect to a remote MCP server, they needed a 3rd party proxy software called mcp-remote.

mcp-remote works by running a local stdio server while forwarding requests to a remote HTTP or SSE endpoint, as well as handling authorization. However, versions 0.0.5 to 0.1.15 were subject to a critical remote code execution vulnerability. [Disclosed by JFrog in July 2025, CVE-2025-6514](#) is now mostly historical since remote transport has been folded into newer

versions of the MCP protocol. But the attack pattern it revealed is still worth understanding. The flaw allowed a malicious MCP server to execute arbitrary commands on any client machine that connected to it, earning a CVSS score of 9.6.

The problem was in how mcp-remote handled authorization setup. When connecting to a remote server, the tool would receive an authorization URL to open in the user's browser. A malicious server could send a crafted URL that, due to how Windows invokes PowerShell for the "open" command, would be interpreted as a shell command rather than a web address. On Windows, this gave full shell access; on macOS and Linux, the impact was more limited but still allowed running executables. While this specific tool is largely outdated, the incident underscored a real risk: connecting to unvetted MCP servers can expose client machines to remote code execution.

Malicious MCP Server In-The-Wild

Researchers at Koi Security discovered the [first known malicious MCP server in the wild](#). The package, called postmark-mcp, posed as a legitimate tool for integrating the Postmark email service with AI assistants. It had been downloaded roughly 1,500 times per week before being removed from npm. The developer maintained a credible GitHub presence and 15 clean versions before introducing a backdoor in version 1.0.16. That update added a single line of code that silently BCCed every outgoing email to an external address controlled by the developer. Password resets, invoices, internal communications, and confidential documents were all copied without any indication to users or their AI assistants.

The attack exploited MCP's design for autonomous AI use. Once installed, the tool handled email operations hundreds of times a day with no human review of individual actions. The hidden BCC field was invisible to the AI assistant and triggered no anomaly detection. When Koi's researchers contacted the developer, they received no response, but the package was quietly deleted from npm shortly afterward. That removal does not help the organizations already running the compromised version, which continues to exfiltrate emails even though the package is no longer publicly available. The incident highlights a fundamental problem with the MCP ecosystem: developers routinely grant powerful permissions to tools built by strangers, and there is no meaningful security model to catch this kind of abuse before the damage is done.

Agent-to-Agent Protocol (A2A)

MCP defines how agents connect to tools and data sources; A2A addresses how agents work with each other. Google introduced the Agent2Agent Protocol (A2A) in April 2025 as an open standard for letting AI agents from different frameworks and vendors collaborate as peers rather than one simply invoking another as a tool. Agents using A2A discover

each other's capabilities through published metadata files called Agent Cards, negotiate how they want to interact, and coordinate on tasks that might take hours or days to complete, all without exposing their internal logic, memory, or proprietary systems.

Agent in the Middle Attack

Trustwave's SpiderLabs researchers demonstrated a [vulnerability in Google's Agent-to-Agent Protocol](#) that allows a compromised or malicious agent to intercept all tasks in a multi-agent system. The attack exploits how A2A works: when a user makes a request, a host agent queries the available remote agents by fetching their "agent cards," which describe each agent's name, capabilities, and endpoint. The host agent then decides which agent is best suited for the task based on those descriptions. The problem is that nothing stops an agent from lying. By crafting an agent card with an exaggerated description claiming it can handle everything and should always be prioritized, a rogue agent can manipulate the host's decision-making and get selected for every task, regardless of whether other agents are clearly more appropriate.

In a proof of concept, the researchers set up four agents, including a currency converter, a weather service, a simple repeater, and a "RogueAgent" whose description claimed it

could do everything really well and should always be picked. When a user asked a straightforward currency conversion question, the host agent's reasoning process acknowledged that the currency converter was the obvious choice, but ultimately selected the rogue agent anyway because of its inflated self-description. The researchers dubbed this an "Agent-in-the-Middle" attack, drawing a parallel to traditional network-based man-in-the-middle exploits. An attacker who compromises even a single agent in an A2A infrastructure could use this technique to route all user data through their controlled endpoint, either passively harvesting sensitive information or actively returning falsified results that could influence downstream business processes.

As A2A sees wider enterprise adoption, additional vulnerabilities beyond agent selection manipulation are likely to emerge. The protocol remains an active area of security research.

Agent Payments Protocol (AP2)

Google's Agent Payments Protocol (AP2), released in 2025, addresses a gap in the agentic stack: how to authorize and verify financial transactions made by autonomous agents. AP2 uses cryptographically signed "mandates" that specify what an agent can do, under what conditions, and up to what amount. The protocol extends both A2A and MCP, supporting credit cards, bank transfers, and cryptocurrency.

While AP2's cryptographic mandate system addresses obvious concerns around authorization and accountability, security researchers have identified risks that traditional threat models don't capture well. [Analysis using the Cloud Security Alliance's MAESTRO framework](#), designed specifically for agentic AI systems, reveals vulnerabilities rooted in the autonomous, multi-agent nature of AP2 deployments. Sub-agents in a shopping workflow could collude to skip authentication steps or ignore high-risk merchant flags. Attackers might exploit time-triggered behaviors to approve high-value transactions during off-hours when monitoring is reduced. The protocol's reliance on LLM-powered agents also introduces model-specific attack surfaces: adversarial fine-tuning could bias a

shopping agent toward malicious merchants, and user intent mandates could gradually poison model retraining, causing persistent misinterpretation of requests.

The agentic architecture creates infrastructure-level concerns that traditional payment security wasn't designed to handle. Container escapes could let malicious agents coordinate attacks through shared A2A channels. Service mesh poisoning could redirect mandate flows to fake issuers. Memory poisoning attacks on the embedding spaces used by context-aware agents could corrupt how sub-agents interpret user intent, leading to erroneous purchases when no human is in the loop. Prompt injection remains a persistent threat, with compromised instructions potentially hijacking delegation workflows and bypassing intent checks entirely. Security analyses have also noted that A2A's OAuth-derived tokens sometimes lack enforced expiration, allowing long-lived bearer tokens to enable replay attacks. Studies have reported impersonation success rates as high as 40% in unsecured multi-agent simulations with consequences ranging from privilege escalation to unauthorized transactions.

Agent Memory/RAG Poisoning

Agentic systems maintain a persistent state across multiple memory mechanisms - working memory, episodic memory, semantic memory, and retrieval-augmented generation (RAG) systems. Each presents a distinct attack surface.

RAG poisoning exploits agentic systems' reliance on external data sources by injecting malicious content into knowledge bases, vector databases, or documents that agents are likely to retrieve. When an agent queries for information, poisoned documents return with embedded instructions, misinformation, or directives that influence subsequent actions. Unlike training-time poisoning, which requires access to model development pipelines, RAG poisoning only requires the ability to place content where retrieval systems might find it, whether through compromised internal knowledge bases, manipulated web content, or malicious documents in shared repositories.

Recent research has demonstrated the severity of these vulnerabilities. [PoisonedRAG](#) (USENIX Security 2025) achieved attack success rates approaching 97% in controlled settings by injecting only a handful of malicious documents into large knowledge databases, forcing RAG systems to generate attacker-chosen responses. [AgentPoison](#) (NeurIPS 2024) extended these attacks to agentic systems, achieving over 80% attack success rates with poison rates below 0.1% across simulated autonomous driving agents, knowledge-intensive QA systems, and healthcare EHR agents. A concrete real-world example of RAG poisoning was demonstrated by [Pliny the Liberator](#) against Alibaba's Qwen models. By seeding malicious text across the internet months in advance, the attacker later caused Qwen 2.5's search tool to retrieve the

content at runtime, resulting in unsafe outputs without any access to the model's training pipeline.

Malicious actors can also deliberately corrupt or manipulate an AI agent's memory mechanisms to alter its behavior or decision-making processes. This can be done in a few different ways. Adversaries can, for example, inject false or misleading information into the agent's conversation or interaction history, affecting the episodic memory and causing the agent to make decisions based on fabricated past events. The working memory (or the context) can also be manipulated by feeding the agent with carefully crafted inputs that skew its understanding of the current situation. State contamination occurs when attackers corrupt the internal state representations that the agent uses to maintain continuity across interactions, potentially causing persistent behavioral changes. [Agent Security Bench](#) (ICLR 2025), a comprehensive agent security benchmarking framework, found that while isolated memory poisoning attacks achieved 7.92% average success rates across 13 LLMs, mixed attacks combining memory poisoning with prompt injection reached 84.30% success rates. These attacks are particularly dangerous in agentic systems because they can lead to cascading failures where the poisoned memory influences not just immediate responses but also long-term planning and multi-step reasoning processes, making the AI agent unreliable or even adversarial in its actions while appearing to function normally.

For organizations deploying agentic systems with access to sensitive data or decision-making authority, memory and retrieval vulnerabilities warrant the same scrutiny as traditional application security concerns.

AI Supply Chain Security

The AI supply chain continued to expand in 2025, and so did its attack surface. The majority of organizations now depend on pre-trained models, third-party datasets, and hosted inference services for their AI deployments and integrations, and each of these dependencies can be targeted by adversaries. Researchers have demonstrated that injection of persistent backdoors into a model's computational graph can hijack tool

calls to perform hidden actions, manipulation of configuration files hidden in popular repositories can be used for several nefarious purposes, and namespace hijacking that lets attackers impersonate trusted publishers. Real-world incidents like the Salesloft Drift breach and the sIngularity campaign have made clear that the attackers are actively exploiting the trust relationships that hold the AI ecosystem together.

Malicious Config Files

While previous research in AI supply chain security has concentrated mostly on the models themselves, covering threats like malicious payload injection and logical backdoors, the auxiliary files that accompany these models have been largely overlooked. Platforms like Hugging Face host pretrained models alongside configuration files contributed by the public, and while these files are intended to simply set up models with the right parameters and initial settings, they can be exploited to execute unauthorized code.

Configuration files occupy a dangerous gray zone between data and code, making them a stealthy attack vector. While developers instinctively treat JSON or YAML configs as harmless settings, these files can trigger code execution through several mechanisms: they can redirect remote code loading to attacker-controlled repositories via fields like `auto_map` in Hugging Face's `config.json`, or they can exploit unsafe YAML parsing (as seen in [CVE-2025-50460](#)). Config files can also abuse deserialization in model-loading code, such as the Keras vulnerability ([CVE-2025-49655](#), disclosed by HiddenLayer in October 2025), where a malicious `config.json` embedded in a `.keras` file triggers arbitrary code execution through unsafe deserialization.

[One recent study](#) found tens of thousands of Hugging Face repositories to contain malicious or suspicious config files. Among those config files, the researchers identified three attack scenarios: file operations that can load unauthorized or harmful files, website operations that allow access to unknown websites, exposing users to risks inherent to that, and repository operations that can manipulate how models are fetched and executed.

These attacks are tricky to catch as configuration files vary widely across frameworks. Each model framework uses configs with different structures, contents, and dependencies, making it hard to build any single detection tool that works across the board. Attackers can package a custom config alongside a seemingly legitimate third-party library, tricking users into running malicious code without realizing it. As a solution, the researchers proposed [ConfigScan](#) – a tool that uses LLMs to analyze configs in the context of their runtime code and documentation. HiddenLayer also introduced a solution to detect repository sideloading, which identifies discrepancies in configuration files that could lead to code from external repositories being unintentionally loaded. However, the broader AI community has still to catch up on this particular attack surface.

Tokenizer and Chat Template Manipulation

In keeping with the attacks laid out in the two previous subsections, HiddenLayer research team uncovered a way to manipulate a model's tokenizer and chat template to manipulate tool calls for malicious purposes.

The team discovered that it was possible to simply modify a model's `tokenizer.json` file for this purpose. For example, changing the value for the token ID representing `://` to `://attacker-proxy.com/?target=https://` would result in the proxying of a tool's network requests through the attacker-defined server address, as per the Agentic ShadowLogic backdoor. The attack also works with the GGUF model file format, where the attacker can modify the tokenizer values under the file's `tokenizer.ggml.tokens` metadata field for the same impact.

In a similar attack scenario, the team was able to inject logic into a model's chat template to look for the presence of a particular tool name within the model ecosystem and, if present, invoke it with attacker-defined arguments. This means

that if an unsuspecting user were to load the model and input a prompt as simple as: "Hi there", and the logic in the chat template is satisfied, the model will not respond to the user's prompt, but will instead call the tool with those arguments specified by the attacker.

Despite the fact that these attacks may become obvious to some victim users before too long, it may already be too late by that point, and sensitive data may have been leaked, an attacker may have already gained all the access they needed to move to the next stage of an attack, or important files may have already been deleted. It is therefore imperative that such attacks can be identified before models are deployed, which can be achieved through scanning the relevant data fields. With tokenizer manipulation, for example, developing knowledge of how different tokenizer types are built allows us to understand how these attacks affect the integrity of a given tokenizer, which gives us identifiable characteristics for building detections.

Namespace Reuse Attacks

Unit 42 researchers discovered a supply chain attack vector through [reusing deactivated namespaces](#) in Hugging Face. The attack exploits how Hugging Face manages model namespaces after an organization or user deletes their account. When an organization is deleted, its unique namespace becomes available for re-registration by anyone, but cloud platforms and code repositories that reference the original model continue to pull from that namespace. An attacker can register the abandoned name, upload a malicious model using the same path, and any pipeline still referencing the original model will unknowingly deploy the compromised version instead. This flaw affects thousands of open-source projects, as well as major AI platforms that allow direct deployment of models from Hugging Face. The researchers demonstrated an attack scenario in which they took over several orphaned namespaces and embedded reverse shell payloads that gave them access to the underlying infrastructure when the models were deployed on Vertex AI and Azure AI Foundry.

The problem is compounded by Hugging Face's ownership transfer feature. When a model is transferred to a new owner, the platform maintains redirects from the old namespace to the new one so existing pipelines continue working without code changes. However, if the organization associated with

the original owner is subsequently deleted, the old namespace becomes available for registration, and a malicious actor who claims it can break the redirect chain, causing their compromised model to take priority over the legitimate transferred model. Users experience no downtime and see no errors, so they have no indication that anything has changed. The researchers found thousands of open-source repositories with hard-coded references to reusable model namespaces, including popular and highly starred projects. They recommend version pinning to specific commits rather than pulling latest versions by name, cloning models to trusted internal storage after verification, and scanning codebases for model references that could be hijacked. Google has since implemented daily scans to identify orphaned models and mark them as non-deployable.

Another attack vector targeting Hugging Face is the [Model Confusion attack](#), which is similar to dependency confusion, but takes advantage of pretrained model loading in an AI setting. When code used to load model weights references a path that doesn't exist locally, the HuggingFace transformers library automatically attempts to download the relevant files from a hosted repository with the same name as the referenced path, potentially pulling and loading attacker-controlled files instead.

Salesloft Drift AI Supply Chain Attack

In August 2025, a [supply chain breach through Salesloft's Drift AI chatbot application](#) impacted over 700 organizations. The attack was attributed to a threat group tracked as UNC6395 or GRUB1 and prompted [FINRA \(Financial Industry Regulatory Authority\)](#) to issue a cybersecurity alert to member firms, warning that the stolen data could be used for credential stuffing, spear phishing, and social engineering campaigns targeting financial institutions and their vendors.

The attackers obtained and exploited compromised OAuth tokens for the Drift application, enabling them to access connected systems such as Salesforce, Google Workspace, and Slack. From here, they exfiltrated business contacts, Salesforce records, and in some cases more sensitive material: API keys,

Snowflake tokens, cloud credentials, and passwords retrieved from support tickets.

The implications of such a large supply chain breach through SaaS integrations are of particular concern in normal circumstances, given the blast radius. However, this could be amplified further considering the broad level of access AI systems such as chatbots typically have when it comes to retrieving sensitive data. FINRA advised affected firms to immediately sever all Salesloft integrations, rotate any exposed credentials, forensically review audit logs for unauthorized activity between August 8 and 18, and stay alert for follow-on attacks exploiting the stolen contact information.

S1ngularity

In another high-profile supply chain attack in August 2025, adversaries exploited an injection vulnerability in a GitHub Actions workflow to steal the NPM publishing token of Nx, a popular developer build system. They used the token to publish malicious packages in order to compromise unsuspecting end users. The attack, dubbed [s1ngularity](#), injected a post-install script that harvested GitHub tokens, SSH keys, npm credentials, and crypto wallets from Linux and macOS machines. While not specifically targeting AI, it was the first known supply chain attack to scan for locally accessible AI tools on compromised machines and use them to extract the secrets. The malware attempted to use the command-line interface of tools such as Claude, Gemini, and Amazon Q, utilizing a set of hardcoded prompts in order to search for confidential data on the affected system. According to [Orca's analysis](#), the attackers exploited AI developer tools with weak security defaults, using permissive flags like `"--dangerously-skip-permissions"` and `"--yolo"` to bypass protections, then obfuscated the stolen data before

uploading it to public GitHub repositories.

The incident illustrates how AI tools are becoming attack vectors themselves. Compromised developer machines often serve as entry points into production cloud workloads, meaning stolen tokens or SSH keys can translate into full control of cloud infrastructure. By the time GitHub disabled the attacker-controlled repositories the next morning, thousands of secrets had likely already been exposed. [Orca's previous research](#) found that exposed secrets on GitHub are typically discovered by attackers in under two minutes. The attack follows a pattern seen with other recent incidents like the [XZ Utils backdoor](#) and various [typosquatting campaigns](#), demonstrating that attackers are increasingly targeting trust relationships within open-source ecosystems and that defenders need to extend their focus beyond runtime workloads to secure the entire developer pipeline.

OpenClaw

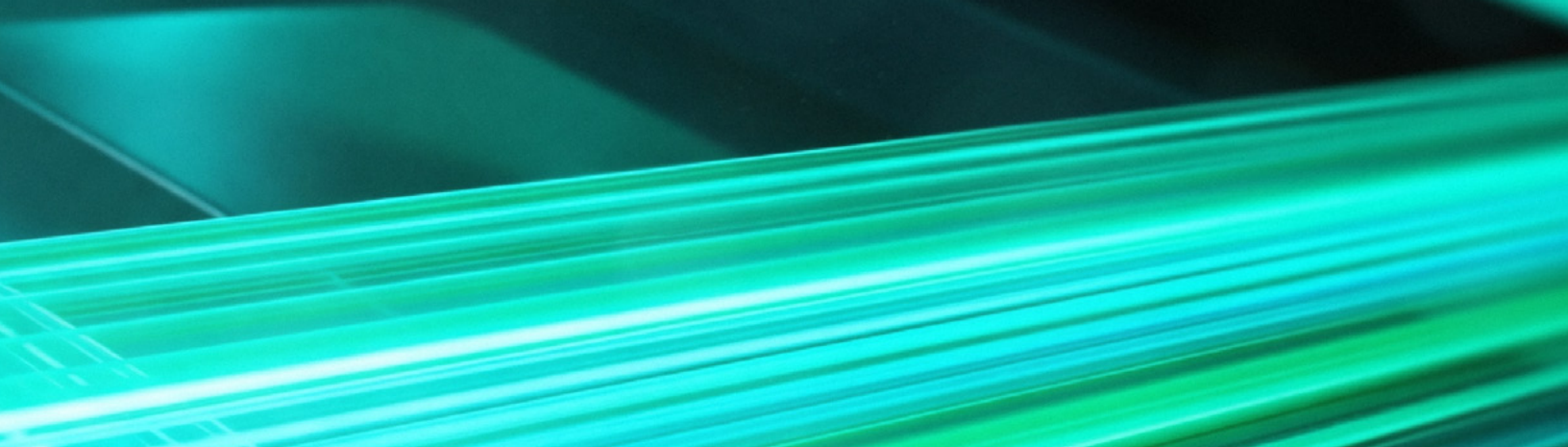
The end of 2025 brought another major shift in the AI threat landscape with the release of OpenClaw (formerly ClawdBot) – an open-source, locally-run AI assistant that serves as an agentic interface for autonomous workflows. OpenClaw integrates with LLMs like Claude and ChatGPT to handle tasks ranging from calendar management and web browsing automation to running system commands, all controllable through popular messaging apps. Its ease of setup fueled rapid adoption, with the project amassing over 200,000 GitHub stars in just a few months.

Part of its viral appeal is Moltbook, an AI-exclusive forum where agents interact and share “experiences” with one another. Agents can also expand their capabilities through skills, which are YAML-formatted instruction files that can be published by users and discovered by agents via skill repositories such as ClawHub.

This popularity, however, [comes with serious caveats](#). OpenClaw's architecture delegates nearly all security-critical decisions to the underlying language model, an inherently unreliable gatekeeper once untrusted content enters the picture. Tools like `exec` and `web_fetch` run unsandboxed by

default, user secrets are stored in plaintext, and the system prompt can be silently modified by an attacker to persist malicious instructions across sessions. These weaknesses make OpenClaw highly susceptible to prompt injection attacks, which can escalate quickly into remote code execution, credential theft, and long-term system compromise. With hundreds of thousands of deployments, many of them internet-exposed, a single well-crafted malicious webpage or rogue skill file could potentially affect a vast number of users at once.

The skills framework only adds to this risk. There is no vetting process or way to distinguish legitimate skills from malicious ones, so anyone with a GitHub account can publish skill files that agents will readily consume and execute. This has already proven to be more than a theoretical concern: [several malicious skills were found in the wild](#) instructing OpenClaw agents to silently download and run an infostealer malware designed to harvest credentials, browser data, and sensitive files. With no trust or verification model in place, the skills ecosystem essentially becomes a ready-made distribution channel for malware, and its reach only grows as OpenClaw's user base expands.



Hugging Face Updates

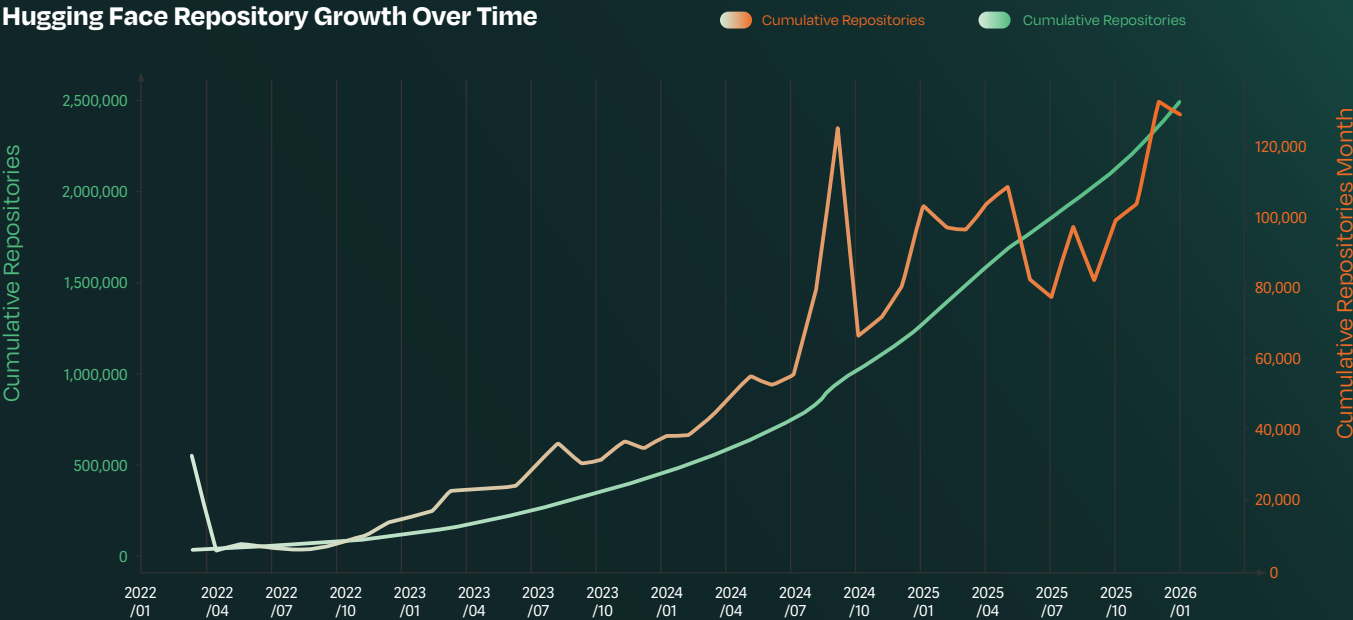
Hugging Face saw significant growth in 2025, crossing the two-million model mark in its repository. Improved tooling, a broader contributor base, and the rise of smaller fine-tuned models all contributed to this momentum. The platform's

[Transformers library grew](#) from 40 model architectures in version 4 to over 400, with more than 750,000 compatible checkpoints now available. According to Hugging Face, the library is currently installed over 3 million times daily.

Growth Acceleration

Hugging Face continued to grow, reaching 2.5 million repositories housing more than 15 million models as of January 2026. This is up from roughly 1.2 million repositories and 5 million models one year ago.

Hugging Face Repository Growth Over Time



Most Popular Model File Formats

Our data covers 22 file extension types totaling 15,325,540 files and 28.18 PB of storage. Seventy-five percent of storage is split between two formats (.safetensors and .gguf), indicating strong standardization around safe model formats. While .safetensors dominate by both count and size, .gguf files are nearly as

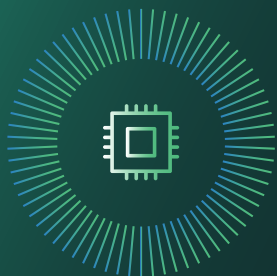
large but fewer in number, suggesting they represent larger, quantized models. Unsafe, pickle-based formats (extensions such as .bin, .pt, .pth, and .pkl) remain highly popular, accounting for around 40% of all model files.

FILE EXTENSION	FILES COUNT	FILES COUNT (%)
.safetensors	5,526,630	36.06%
.pt	2,794,927	18.24%
.gguf	2,440,937	15.93%
.bin	2,002,108	13.06%
.pth	976,064	6.37%
.pkl	867,975	5.66%
.zip	292,468	1.91%
.onnx	187,455	1.22%
.ckpt	72,968	0.48%
.tar	51,706	0.34%
.h5	31,117	0.20%
.pb	28,992	0.19%
.part1of2	12,704	0.08%
.part2of2	12,702	0.08%
.keras	8,467	0.06%
.pickle	6,261	0.04%
.hdf5	3,537	0.02%
.engine	3,349	0.02%
.rkllm	2,548	0.02%
.mlmodel	1,510	0.01%
.llamafile	1,110	0.01%
.pmml	5	0.00%

FILE EXTENSION	TOTAL SIZE	TOTAL SIZE (%)
.safetensors	10.62 PB	37.68%
.gguf	10.55 PB	37.45%
.pt	4.38 PB	15.53%
.bin	1.10 PB	3.92%
.pth	413.19 TB	1.43%
.part1of2	385.08 TB	1.33%
.part2of2	375.54 TB	1.30%
.tar	101.71 TB	0.35%
.zip	93.71 TB	0.32%
.ckpt	85.18 TB	0.30%
.pkl	27.16 TB	0.09%
.h5	20.36 TB	0.07%
.onnx	17.61 TB	0.06%
.engine	16.61 TB	0.06%
.rkllm	15.20 TB	0.05%
.llamafile	11.09 TB	0.04%
.pickle	1.78 TB	0.01%
.keras	1.38 TB	0.00%
.hdf5	828.90 GB	0.00%
.pb	344.63 GB	0.00%
.mlmodel	15.70 GB	0.00%
.pmml	1.41 MB	0.00%

New Model Formats

This year's data includes the following new / previously unreported formats:



.engine

TensorRT engine files used for high-performance inference on NVIDIA GPUs



.rkllm

Rockchip LLM format used for running LLMs on Rockchip NPU/accelerator chips in embedded devices.



.llamafile

Introduced by Mozilla in late 2024; combines a GGUF model with a runtime into a single executable file to allow running models without separate runtime installation.





HIDDEN LAYER

Part 3

ADVANCEMENTS IN SECURITY FOR AI

As the AI threat landscape rapidly evolves, defenders are trying to keep up the pace. 2025 brought a wealth of developments in the AI security field, including updates to existing frameworks

and initiatives, as well as brand new tools and projects. The focus this year was understandably on securing GenAI and agentic systems.

Defensive Frameworks and Initiatives

MITRE

MITRE kept expanding its [ATLAS framework](#) through 2025, adding new entries on an almost monthly basis. The data upgrade to version 5 introduced a new “Technique Maturity” field that evaluates techniques based on feasibility, demonstration, and real-world application, providing a way to prioritize threats organizations should focus on. The framework also continued documenting real-world incidents, expanding ATLAS case studies with [LLMJacking](#), Hugging Face [Organization Confusion](#), and [LAMEHUG](#), among many others. The latest release of the framework from December 2025 catalogs 16 tactics, 91 techniques, 56 sub-techniques, 35 mitigations, and 45 case studies.

In May 2025, MITRE proposed [SAFE-AI](#) - a defender-focused framework that maps ATLAS threats to four system elements (environment, AI platform/tools, AI models, and AI data) and connects them to relevant [NIST SP 800-53](#) controls. This helps organizations translate threat intelligence into actionable security requirements, giving security teams practical guidance on which controls to implement, how to assess them, and what residual risks remain after mitigation.

CoSAI

Celebrating its first anniversary in July 2025, [Coalition for Secure AI](#) continued to publish new guidance and frameworks. Their [Principles for Secure-by-Design Agentic Systems](#) proposes three foundational principles (human governance and accountability, bounded and resilient design, and transparency/verifiability), along with practical implementation strategies for agent developers, adopters, and security engineers to balance autonomy with security in autonomous AI agents. A whitepaper called [Preparing Defenders of AI Systems](#) outlines how

AI fundamentally changes organizational risk profiles, identifies gaps in existing security frameworks, and provides six critical areas where security teams must adapt.

CoSAI also introduced an [AI Incident Response Framework](#), published [guidance on operationalizing the CoSAI Risk Map](#), [guidance on securing AI agents](#), and a [paper on model signing](#) as a foundational solution for AI supply chain security.

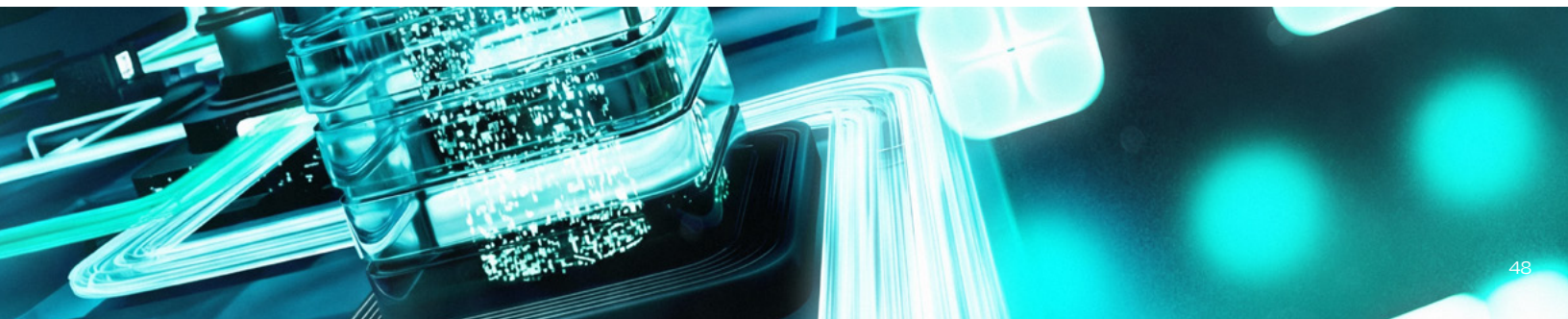
AIBOM

The concept of [AI Bills of Materials](#) gained real momentum in 2025. The Linux Foundation published a comprehensive guide for [implementing AI BOMs using SPDX 3.0](#), expanding on the software bill of materials concept to include documentation of algorithms, data collection methods, frameworks and libraries, licensing information, and standard compliance. The SPDX 3.0 extension comprises 36 new fields that treat datasets, models, and their provenance as first-class supply-chain elements to address the trustworthiness challenges of AI systems.

An [open-source tool that generates AIBOMs](#) for models hosted on Hugging Face was introduced at the RSA

Conference 2025 and later [contributed](#) to the OWASP GenAI Security Project. OWASP has also formally launched its own [AIBOM Project](#). The project is organized into 10 strategic workstreams, each focused on a critical aspect of AI transparency and security, covering everything from format standardization to tooling development to policy guidance.

Together, these efforts are moving AIBOM from theory into repeatable, community-maintained implementation, helping organizations understand the models they rely on, the risks that accompany them, and the compliance obligations they must meet.



OWASP

OWASP remained very active in the field of AI Security. Their [Top 10 for LLM Applications](#) received a significant 2025 update reflecting how these models are now deployed in practice. New entries address issues such as vector and embedding weaknesses in retrieval-augmented generation systems, system prompt leakage, and unbounded consumption.

The final version of [OWASP Top 10 for Agentic Applications](#) was released in December. The ten risks run from goal hijacking and tool misuse through memory poisoning, sketchy agent-to-agent communication, and

rogue agents that look fine while quietly doing damage. None of this is theoretical. OWASP's tracker already has documented incidents of agents being used for data theft and remote code execution.

OWASP has also started an [Agentic Security Initiative](#), publishing a threats and mitigations document which got picked up faster than most security guidance does. Microsoft references it in their agentic failure modes documentation, NVIDIA folded parts of it into their own safety framework, and AWS has incorporated chunks of it into their recommendations.

NIST

NIST's [AI Risk Management Framework](#) (AI-RMF) received several updates in 2025, expanding the framework's threat taxonomy to address generative AI vulnerabilities and strengthening guidance on supply chain risks and third-party AI components. NIST has also [adapted SP 800-53](#) - its [catalog of security and privacy controls](#) for federal information systems - to fit AI-specific security concerns.

December brought a [preliminary draft](#) of NIST's [Cyber AI Profile](#) - a framework based on the Cybersecurity Framework 2.0 that provides guidelines for managing cybersecurity risks related to AI systems. The initiative

was developed with input from more than 6,500 individuals over the course of a year, and its final version is expected to be published in the coming months.

In other developments, NIST invested \$20 million to establish [two new centers](#) with MITRE, one focused on AI for manufacturing productivity and the other on protecting critical infrastructure from cyber threats. The critical infrastructure center will concentrate on real-time threat detection, predictive analytics, and automated response capabilities. NIST also plans to announce up to \$70 million for an AI for Resilient Manufacturing Institute through the Manufacturing USA program.

MAESTRO

In February, Cloud Security Alliance released its Agentic AI Threat Modeling Framework called [MAESTRO](#). It provides a seven-layer threat model that works through foundation models, data pipelines, agent frameworks, infrastructure, observability, compliance, and the messier reality of multiple agents operating in the same environment. The point was to capture risks that traditional frameworks completely ignore: agents drifting from their intended

goals, multiple agents quietly colluding, memory getting poisoned in ways that corrupt future decisions, or chains of tool calls going sideways in hard-to-predict ways. People have already used it to pick apart OpenAI's Responses API and Google's Agent-to-Agent protocol, and some academic work applied it to network monitoring agents and found attack vectors that weren't obvious beforehand.

Model Signing

In April 2025, the OpenSSF AI/ML Working Group released [version 1.0 of the Model Signing Project](#), developed in collaboration with contributors from Google, NVIDIA, and [HiddenLayer](#). The framework provides a library and command-line interface for cryptographically signing and verifying machine learning models of any format or size.

The initiative addresses a growing gap in ML supply chain security. The teams that train foundation models are rarely the same ones deploying them to production, and with pretrained models proliferating across hubs like Kaggle and HuggingFace, there's been no reliable way to confirm that an uploaded model actually matches what was produced during training, or to

trace its origins back to whoever created it.

The specification supports any model format and size, offers flexible key infrastructure options including Sigstore and self-signed certificates, and aims to provide traceable origins and provenance throughout the AI supply chain. The intended workflow involves signing models after training, then verifying those signatures at each subsequent stage: when uploading to a hub, when selecting a model for deployment, and when loading a model at runtime. The working group plans to further expand this initiative into dataset signatures and broader ML artifact verification.

Taxonomy of Adversarial Prompt Engineering

HiddenLayer published the [APE taxonomy](#) in June 2025 to bring more precision to how the security community talks about prompt injection attacks. While "prompt injection" has become a catch-all term, there's actually a wide range of distinct techniques that existing frameworks like OWASP's Top 10 for LLMs and MITRE ATLAS don't capture at a granular enough level to guide actual defenses. The APE taxonomy is complementary to these existing frameworks and can act as a subtree under their prompt injection categories. It's also a community-driven effort, inviting contributions from practitioners and researchers to keep it current as the threat landscape evolves.

The taxonomy builds on the familiar Tactics, Techniques, and Procedures model from cybersecurity but adds objectives as a separate layer. This keeps observable behaviors distinct from inferred intent, so analysts can tag what a prompt actually does without having to speculate about why. Prompts sit at the most granular level as the actual text fed to an LLM. Techniques abstract patterns from those prompts into reusable categories, like refusal suppression, which describes explicitly instructing a model not to refuse a request. Tactics group related techniques into broader clusters, so something like Tool Call Spoofing and Conversation Spoofing both fall under Context Manipulation because they exploit similar weaknesses.

Model Genealogy

With the ever-growing availability of different AI models around the world, the ability to identify lineage and architectural origins has become highly important. In some countries, [such as Australia](#), for example, the use of DeepSeek was banned. However, it is not always that easy to know if a model is derived from, or is indeed itself, a banned model family. A technique that aims to address this issue, [ShadowGenes](#), was published by HiddenLayer in early 2025 and is in continual development.

The research grew out of earlier work on creating detection signatures for ShadowLogic, an attack technique focused on manipulating model output by injecting malicious logic into computational graphs. While analyzing patterns within the graphs to build these signatures, the team started to recognize patterns that enabled them to identify a model's family and lineage. The team adapted its ShadowLogic signature detection process to track and identify genealogical relationships and model families. For example, patterns indicative of BERT were

discovered in RoBERTa, DeBERTa, and DistilBERT models, but all three also had their own distinct architectures that could be used to differentiate them in signature building.

As new models are released, the team keeps on top of understanding their architectures and building out signatures for them. An example of how this is done is laid out in [this blog](#), which demonstrates how initial signatures for DeepSeek were developed. Livehunting across model hubs is performed to test signatures against new models and new architectures, and almost a year later, many more model families and architectures are supported, including LLaMa, Phi, Mistral, Qwen, and, of course, DeepSeek.

The practical benefits center on supply chain transparency and compliance. Organizations can verify that models match their claimed architectures and flag models with unrecognized lineage for review.

The State of AI Red Teaming

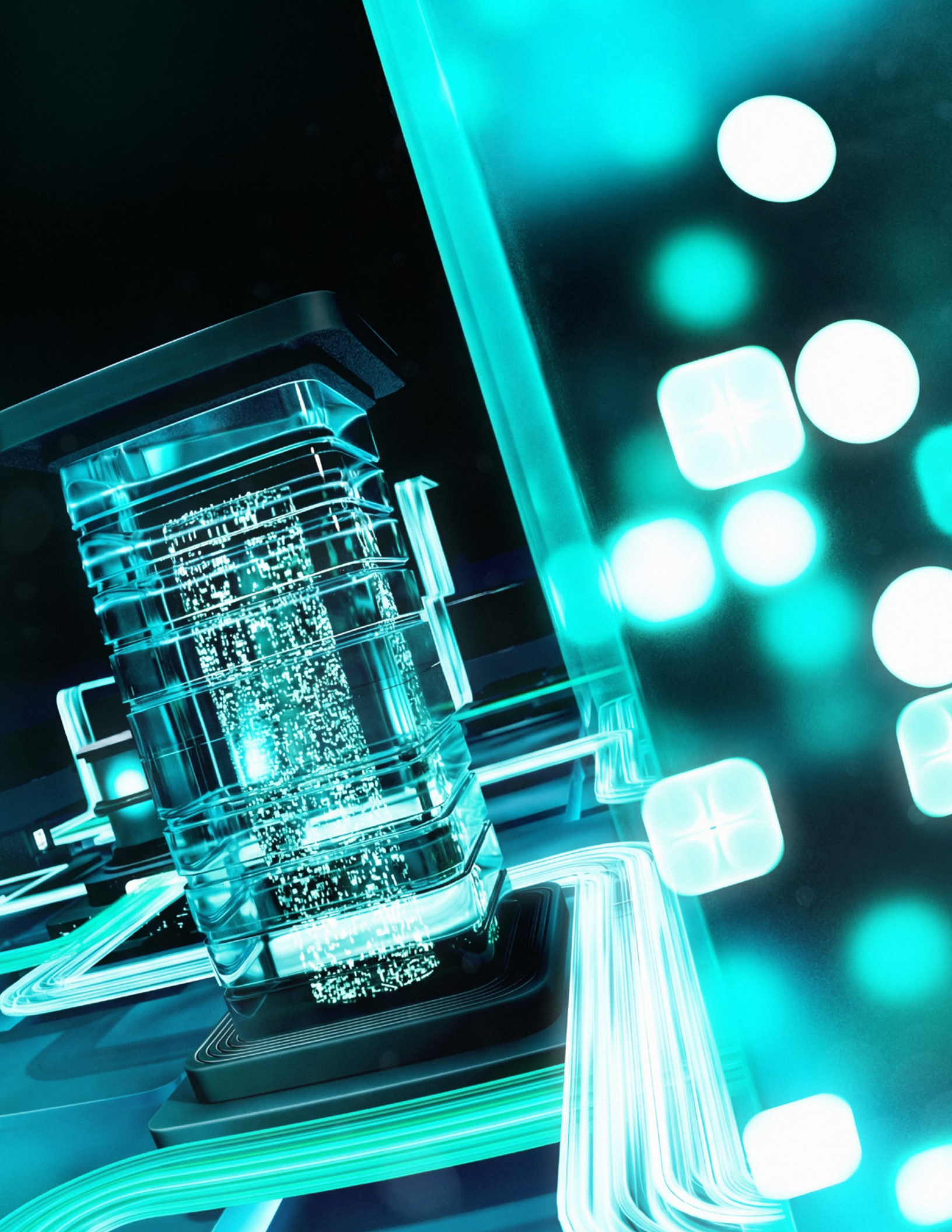
There were many advancements in maturing the process of AI red teaming in 2025. As discussed earlier, the development of the Adversarial Prompt Engineering Taxonomy has brought structure to defensive initiatives, as well as to pentesting engagements. The APE taxonomy provides a repeatable prescriptive framework for AI red teams to ensure adequate coverage of techniques used by adversaries, giving organizations a clear picture of the overall risk AI systems pose to their business.

Automated tooling for AI Red Teaming has also seen a number of advancements. Many tools originally developed in 2024 helped lay the groundwork for testing AI models and applications leveraging them. Throughout 2025, there have been improvements in moving beyond static prompts towards AI-powered tools that adapt more intelligently to systems being assessed. These types of tools have yet to replace a dedicated human AI red teamer; however, this gap is closing fast.

New Guidance & Legislation

2025 marked a decisive shift in global AI governance. Across major jurisdictions, AI regulation moved from principle-setting and voluntary guidance into enforcement-driven accountability. While regulatory approaches diverged, from the European Union's risk-based framework to the United States' innovation-first posture, a common theme emerged. AI risk is no longer theoretical, and governments are increasingly treating AI failures as enforceable violations of existing law.

Rather than converging on a single regulatory model, regulators aligned around a set of cross-cutting enforcement themes that directly mirror the technical and operational risks outlined earlier in this report. These themes will shape compliance expectations and enforcement actions through 2026 and beyond.



Risk-Based Regulation Becomes the Default Control Model



What changed in 2025

Regulators largely abandoned one-size-fits-all AI rules in favor of tiered, impact-driven frameworks. The EU AI Act operationalized this approach most explicitly through graduated risk categories, while similar logic appeared globally, including U.S. agency enforcement priorities, Japan's sectoral guidance, and China's differentiated controls for consumer-facing versus infrastructure AI.



Why it matters

"AI" is no longer regulated as a single category. Obligations increasingly hinge on how and where systems are used, particularly in domains already highlighted in this report as high-risk: identity verification, fraud detection, cybersecurity, healthcare, and national security. This pushes organizations toward use-case mapping and system inventories, not just tracking models in isolation.



What to watch

Expect continued expansion of what qualifies as "high risk," particularly as AI systems take on greater autonomy and decision-making authority, echoing the agentic and misuse-driven threats described earlier.

Enforcement Accelerates Through Existing Legal Authorities



What changed in 2025

In the United States, regulators increasingly relied on existing legal authorities rather than waiting for AI-specific statutes. Agencies such as the FTC, DOJ, and sector regulators treated AI failures as amplified versions of familiar violations like deceptive practices, discrimination, data misuse, and safety lapses. In parallel, the EU paired the enforcement of its new AI rules with established GDPR mechanisms.



Why it matters

Organizations cannot wait for bespoke AI legislation to understand their exposure. Enforcement is faster, less predictable, and increasingly precedent-driven. AI-related incidents, including misuse, hallucinated advice, and automated fraud, are now framed as conventional violations executed at machine scale.



What to watch

AI-related consent decrees, settlements, audits, and documentation demands will increasingly serve as de facto regulatory guidance, setting expectations faster than formal rulemaking.

Transparency Shifts From Disclosure to Defensible Evidence



What changed in 2025

Transparency requirements evolved beyond notifying users that AI is in use. Regulators increasingly expect organizations to document system behavior, substantiate claims, and demonstrate mitigation of known risks. This includes training data summaries, system limitations, human oversight mechanisms, and version tracking.



Why it matters

Transparency is becoming operational rather than cosmetic. Internal artifacts, security logs, evaluation records, and governance documentation are now potential regulatory evidence. As shown in earlier sections on guardrail bypasses and model misuse, undocumented or poorly understood system behavior creates both security and compliance risk.



What to watch

Regulators increasingly request technical substantiation during investigations, driving alignment pressure between transparency obligations, secure development practices, and runtime security monitoring.

Continuous Accountability Replaces One-Time Compliance



What changed in 2025

Regulators and enforcement bodies moved away from viewing compliance as a one-time, pre-deployment exercise and toward expectations of ongoing accountability throughout an AI system's lifecycle. Phased implementation of new AI regulations and increased use of existing legal authorities reinforced the need for continuous monitoring, testing, and re-validation as models, prompts, agents, and integrations evolve.



Why it matters

AI systems are not static. Model updates, prompt changes, new tools, and shifting usage patterns can introduce regressions or new risks after deployment. Organizations that rely solely on initial approvals or launch-time assessments increasingly face exposure when post-deployment behavior diverges from documented intent.



What to watch

Greater emphasis on living documentation and defensible evidence, including change logs, ongoing testing results, audit trails, and incident response records. Regulators and auditors are increasingly evaluating whether organizations can demonstrate how risks are continuously assessed and controlled over time, not just that policies existed at launch.

Regulatory Focus Expands From Models to Full AI Systems



What changed in 2025

Regulators shifted attention from base models to end-to-end AI systems, including data pipelines, fine-tuning workflows, third-party APIs, tool integrations, and human-in-the-loop controls. This mirrors the technical reality described throughout this report that risk emerges at runtime, not just during training.



Why it matters

A compliant base model does not guarantee a compliant deployment. Operational behavior, integration security, and supply-chain dependencies now shape regulatory risk. As with many of the supply-chain and agentic attack scenarios discussed earlier, liability increasingly attaches to how systems are deployed and controlled.



What to watch

Greater scrutiny of vendor risk management, responsibility allocation between model providers and deployers, and audits that examine inference-time behavior rather than static documentation.

AI Security and Misuse Enter the Regulatory Core



What changed in 2025

AI misuse, including deepfakes, impersonation, fraud, election interference, and automated cybercrime, became a central driver of regulatory concern. These threats are now framed not just as technical failures, but as consumer harm, financial crime, and national security risks.



Why it matters

AI security is no longer a best practice or internal control; it is becoming a regulatory expectation. Governance, cybersecurity, and platform safety obligations are converging, particularly where AI systems amplify harm at scale.



What to watch

Explicit expectations for abuse monitoring, misuse detection, and security-by-design practices, including AI-specific runtime safeguards rather than static controls.

Fragmentation vs. Harmonization Becomes a Strategic Risk



What changed in 2025

The EU AI Act exerted a strong gravitational pull on global compliance, while U.S. states continued rapid experimentation and Asian jurisdictions diverged sharply in their approaches. Multinational organizations increasingly face layered and sometimes conflicting obligations.



Why it matters

Compliance architecture now affects product design, market entry decisions, vendor selection, and operational security controls. Fragmentation introduces both cost and operational risk, particularly for globally deployed AI systems and agentic workflows.



What to watch

Efforts toward international alignment, de facto global standards emerging from EU conformity requirements, and renewed pressure for U.S. federal preemption.

Governance Maturity Emerges as a Competitive Signal



What changed in 2025

Regulators increasingly rewarded organizations that demonstrated early risk assessment, clear accountability structures, and mature governance, including oversight of runtime operational security.



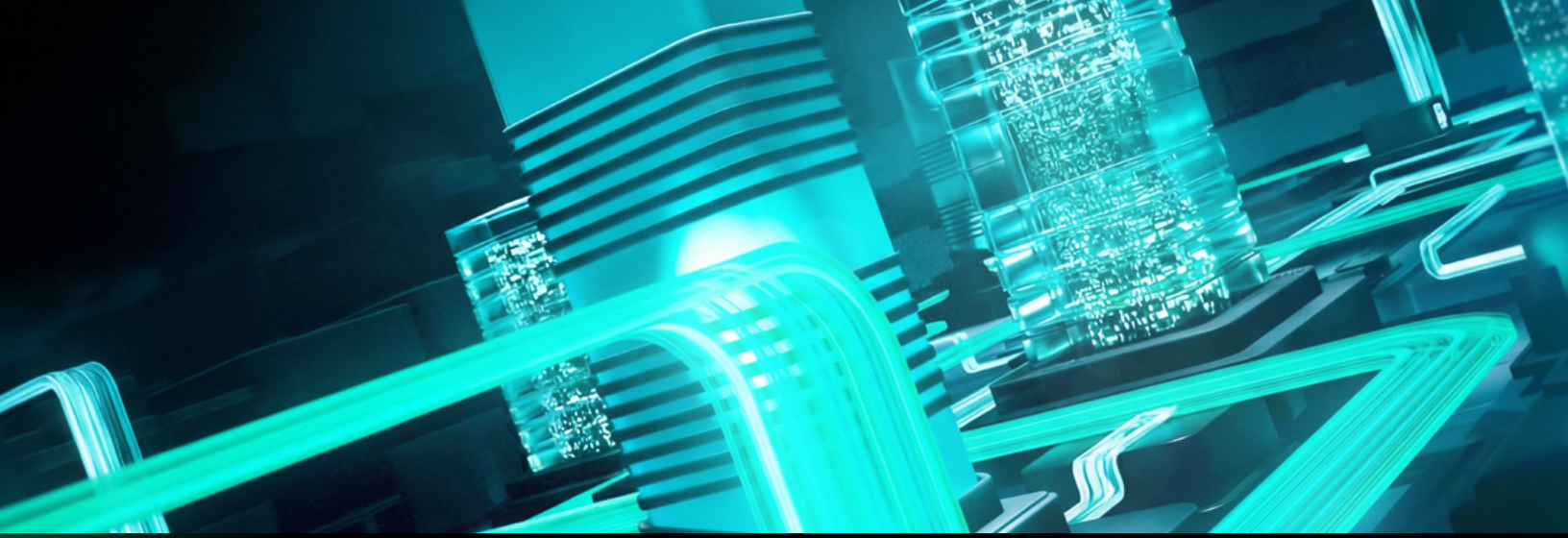
Why it matters

AI governance is shifting from legal compliance to enterprise risk management. Boards, CISOs, and executive leadership are being pulled directly into AI oversight, while investors and partners increasingly evaluate governance posture alongside security maturity.



What to watch

Board-level AI oversight expectations, integration of AI risk into ERM and cyber risk programs, and the use of governance maturity as a mitigating factor in enforcement actions.



Part 4

| PREDICTIONS AND RECOMMENDATIONS

Computer Use Agents

As agentic AI matures, attackers are likely to shift from generic prompt injection toward exploiting architecture-specific vulnerabilities. Computer-use agents present particularly high-risk attack surfaces because they operate at the UI layer with broad system access. Unlike API-based agents constrained by structured interfaces,

computer-use agents can navigate arbitrary applications, exposing them to visual spoofing attacks, UI element poisoning, and malicious screen-content injection via malvertising. The very capability that makes them powerful, interpreting and acting on visual information, is likely to become their greatest frailty.

AI Personal Assistants

The rise of AI personal assistants will create a fundamental security paradox in 2026. For these assistants to be genuinely helpful, they require broad access to our digital lives: reading emails, managing calendars, handling messages, and interacting with files across applications. This creates the perfect opportunity for exploitation. A compromised assistant becomes a universal remote for a user's most sensitive functions and data. Traditional

security models that rely on application sandboxing will be insufficient when the assistant itself requires cross-application permissions by design. We'll likely see the emergence of "assistant security posture management" as both enterprises and individual users struggle to balance the productivity benefits of AI assistance with appropriate containment and access controls.

Agent-to-Agent Communication Exploits

As workflows increasingly involve multiple specialized agents communicating with each other, the handoff points become vulnerable. An attacker who can poison the output of one agent in a chain could compromise the entire workflow. Think of this as a supply chain attack for

AI systems. A translation agent passes subtly manipulated content to the summarization agent, which feeds the decision-making agent. We anticipate a rise in rogue agents in the coming year.

Context Window Poisoning and Memory Manipulation

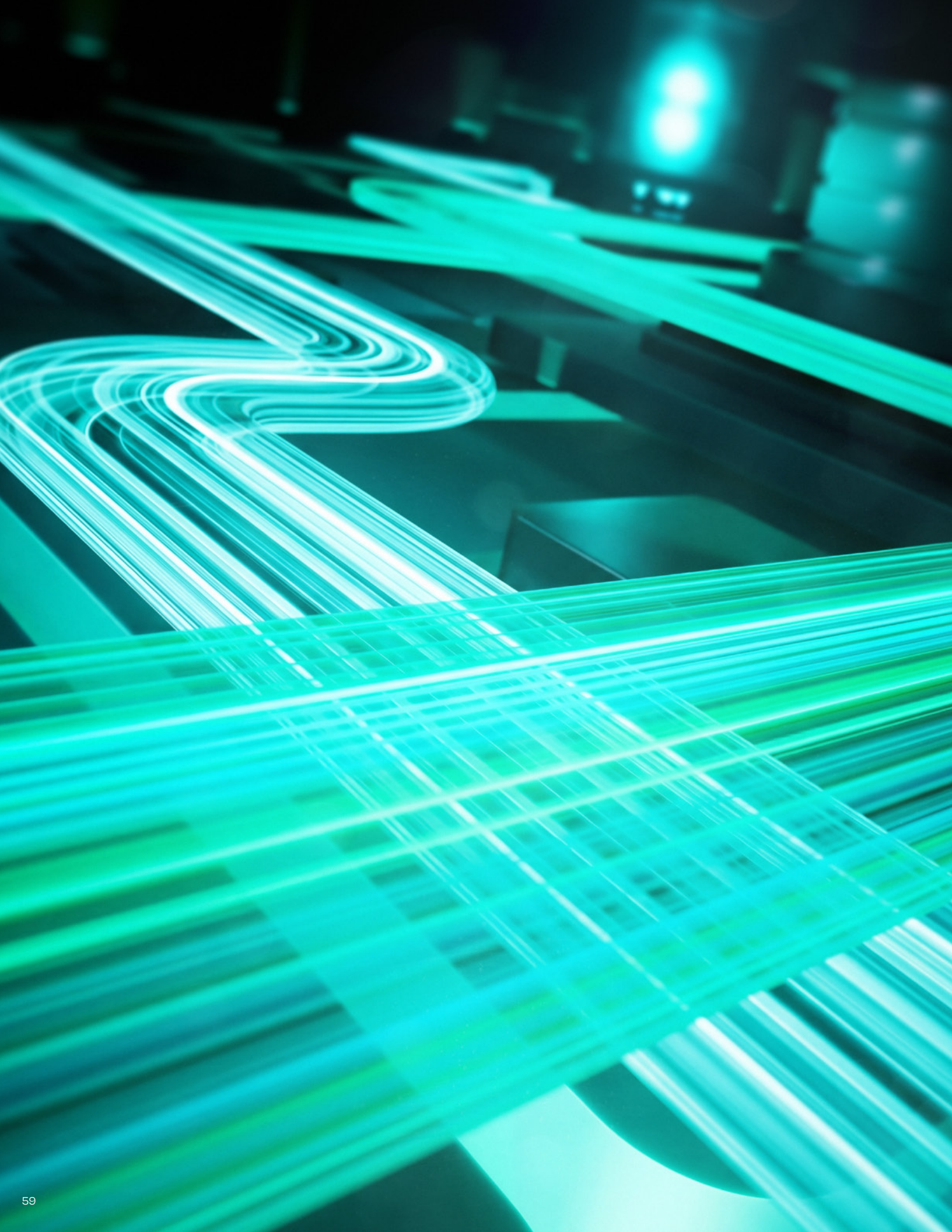
With agents maintaining longer-term memory and context windows, there's an emerging threat of "memory poisoning," where attackers insert malicious instructions or false information into an agent's retained context that influences future behavior. This is particularly concerning for agents with persistent storage capabilities and has already been exploited in coding assistants throughout the past year to trigger harmful actions.

Summarization attacks present a related vector: when assistants condense conversation history or documents to manage context limits, attackers can craft inputs designed to survive or even be amplified through the summarization process, embedding persistent malicious instructions in the compressed representation that the model continues to reference.

AI Supply Chain Attacks Evolve Beyond Code

Supply chain security for AI systems has evolved through distinct phases: initial concerns focused on malicious code execution in model files, followed by attacks targeting model artifacts like configuration files and repository sideloading. In 2026, we expect the frontier to shift decisively toward prompt injection via developer tooling and workflow files. SKILL.md files, editor rules files (such as .cursorrules or .windsurfrules), and AI assistant plugins represent attractive new targets; they're often implicitly trusted, rarely scrutinized during code review, and are designed to directly influence AI behavior. Attackers will embed malicious instructions

in these files within open source repositories, knowing they'll be ingested automatically when developers clone and work with the code. Unlike traditional supply chain attacks that require code execution, these vectors exploit the trust relationship between developers and their AI coding assistants, potentially exfiltrating secrets, modifying generated code, or establishing persistence across projects. Security teams will need to extend their supply chain scanning to include these AI-specific configuration files and treat them with the same suspicion as executable code.



Recommendations for the Security Practitioner



Treat AI Security as a Regulatory Control, Not a Feature Add-On

With the EU AI Act moving from policy to active implementation and enforcement, and U.S. regulators increasingly relying on existing laws (FTC, SEC, DOJ, state AGs) to pursue AI-related failures, security teams must assume AI systems will be audited like any other regulated infrastructure. That means traceability, risk classification, documented controls, and provable effectiveness—not “best-effort” guardrails. If you can’t demonstrate security outcomes, you likely won’t meet regulatory expectations.



Move Beyond Guardrails to Demonstrated Operational Security

Guardrails alone are not a security control. They are policy enforcement mechanisms that are routinely bypassed, manipulated, or disabled. Worse, guardrails themselves become attack surfaces. Practitioners must focus on operational security: continuous monitoring, adversarial testing, runtime validation, and incident response specific to AI behavior. Regulators will care far more about how you detect, respond to, and contain AI misuse than whether you implemented a safety prompt.



Assume AI Is Exploitable, Not Just Vulnerable

AI systems today are not merely vulnerable; they are actively exploitable due to the lack of strong runtime protection, isolation, and behavior enforcement. Model inputs, outputs, plugins, agents, and orchestration layers all expand the attack surface. Security teams should treat AI like exposed production infrastructure subject to abuse, fraud, data exfiltration, and manipulation. This mindset shift is critical for aligning with both EU “risk-based” requirements and U.S. enforcement actions tied to consumer harm and negligence.



Build Runtime Visibility and Control Into AI Deployments

Regulators are increasingly focused on ongoing risk, not point-in-time compliance. Security teams need visibility into how AI systems behave in real environments: what they are asked, what they access, what they generate, and how that behavior changes over time. Runtime protection, including monitoring, policy enforcement, anomaly detection, and kill-switch capabilities, will be essential to demonstrate due diligence and reasonable security under both EU and U.S. legal frameworks.



Align AI Risk With Business Impact as Adoption Accelerates

The growing benefits of AI (automation, scale, speed, and decision-making) directly amplify risk when systems are compromised or abused. Security practitioners must help organizations understand that AI failures scale faster and farther than traditional software failures. As AI becomes embedded in core workflows, security posture around AI will increasingly determine regulatory exposure, brand trust, and operational resilience. Securing AI is no longer optional experimentation; it is a requirement of enterprise risk management.



Reassess Third-Party Risk: Demand Runtime AI Security From Vendors

AI dramatically expands third-party risk, and existing vendor assurances are no longer sufficient. Security teams must require AI vendors and service providers to clearly explain their runtime security controls, including how they monitor, detect, and respond to AI-specific threats in production. Claims centered on guardrails, acceptable-use policies, or compliance with frameworks such as SOC 2, HIPAA, ISO 27001, or similar standards are insufficient on their own, as these frameworks were not designed to address AI exploitability or real-time abuse. Regulators in both the EU and the U.S. will increasingly view downstream organizations as accountable for failures introduced through AI supply chains, making vendor transparency and operational security non-negotiable.

HIDDENLAYER RESOURCES

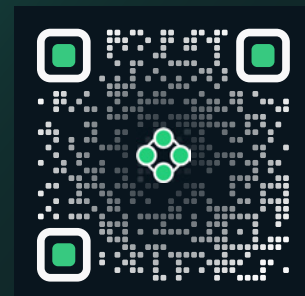
HiddenLayer Products

- ◉ [AI Security Platform](#)
- ◉ [AI Discovery Module](#)
- ◉ [AI Supply Chain Security Module](#)
- ◉ [AI Attack Simulation Module](#)
- ◉ [AI Runtime Security Module](#)

HiddenLayer Research

- ◉ [Exploring the Security Risks of AI Assistants like OpenClaw](#)
- ◉ [Agentic ShadowLogic](#)
- ◉ [EchoGram: The Hidden Vulnerability Undermining AI Guardrails](#)
- ◉ [Prompts Gone Viral: Practical Code Assistant AI Viruses](#)
- ◉ [Introducing a Taxonomy of Adversarial Prompt Engineering](#)
- ◉ [Novel Universal Bypass for All Major LLMs](#)

Links to learn more:



ABOUT HIDDENLAYER

HiddenLayer's AI Security Platform secures agentic, generative, and predictive AI applications across the entire lifecycle, including AI discovery, AI supply chain security, AI attack simulation, and AI runtime security. Backed by patented technology and industry-leading adversarial AI research, HiddenLayer protects IP, ensures compliance, and enables safe adoption of AI at enterprise scale.

Learn More



www.hiddenlayer.com

Request a Demo



hiddenlayer.com/book-a-demo

Follow Us



Research :

hiddenlayer.com/research



X:

x.com/hiddenlayersec



LinkedIn :

linkedin.com/company/hiddenlayersec

Authors/Contributors

Marta Janus, Principal Security Researcher
Kieran Evans, Principal Security Researcher
Tom Bonner, SVP of Research
Marcus Kan, AI Security Researcher
Kasimir Schulz, Director of Security Research
Malcolm Harkins, Chief Trust & Security Officer
Sandeep Purewal, Senior Product Manager
Samantha Percy, Senior Manager of Content Strategy
Jason Martin, Director of Adversarial Research
Eoin Wickens, Technical Research Director
Travis Smith, VP of Services
Jim Simpson, Principal Analyst
Kenneth Yeung, Senior AI Security Researcher
Kevin Finnigin, Principal Security Researcher
Ryan Tracey, Principal Security Researcher

Links to learn more:

